

A stylized illustration of a bank building at night. The building is a classical structure with columns and a pediment. A large, glowing blue Bluetooth symbol is mounted on the right side of the building's facade. The word "BANK" is visible on the left side of the building. In the foreground, a dark-colored car is parked on the street. The background shows other buildings and a dark sky with some floating musical notes. The overall color palette is dark with blue and purple highlights.

Exploiting Bluetooth

From your car to the bank account

Who are we? - Vladyslav

- Bug Bounty hunter - known as yso, schwytz and en_de_ru_cn
- Focus areas include:
 - Web, Mobile, Infra
 - Code Review
 - Development
- Currently open to new opportunities
- OSCP, Meta Awards, MSc in CS.
- Never attacked Bluetooth or cars before



Who are we? - Martin

- Security Researcher & Senior Scientist @ Swiss Cyber-Defence Campus
- Background in wireless security
- Published in all major academic systems security conferences
- Leading research efforts on transportation cyber security at armasuisse
 - Aviation (check out the Aerospace Village)
 - Space
 - Cars
 - Trains
- Also never looked at Bluetooth before but cars, yes

<https://www.brokenwire.fail/>



Supporting Procurement with Security Research - Why?

- **Goal: Already buy (more) secure systems from printers to satellites**

Pre Tender Stage



- Needs Assessment and Requirement Definition
- Market Research and Supplier Identification

Tender Stage



- Bid Evaluation and Selection
- Negotiation and Contract Award

Post Tender Stage



- Performance Monitoring and Evaluation
- Lessons Learned

- **Pen testing** after buying - often too late
- **Vulnerability Research** as early as possible
 - Researching concrete deployed systems -> often too late, even if not bought yet; E.g. transportation systems have long life cycles
 - Researching standards - flaws found may remain for decades

Supporting Procurement with Security Research - How?

- Work with manufacturers and introduce security requirements during procurement process
 - Provide vulnerability reports
 - Help Shape tenders / security requirements
- The **Swiss Cyber-Defence Campus** brings together academia, industry, government (regulators, NCSC, military) to make systems more secure for everyone.
- Our security research can help do that by:
 - Following a responsible disclosure process
 - Publishing scientific papers at academic conferences
 - Open Science practices where possible (publishing code & data on Github et al.)



Vehicles: An army doesn't just have these ...

Source: Werkstatthalle für Panzer in Logistik-Center Hinwil CC BY-NC-ND CC BY-NC-ND



They don't have Bluetooth. I think. I hope.

... but boringly mostly these.

Source: ALC, Logistikbasis der Armee, LBA, Luftaufnahme, Luftbild, Drohnenaufnahme, Drohnenfoto CC BY-NC-ND



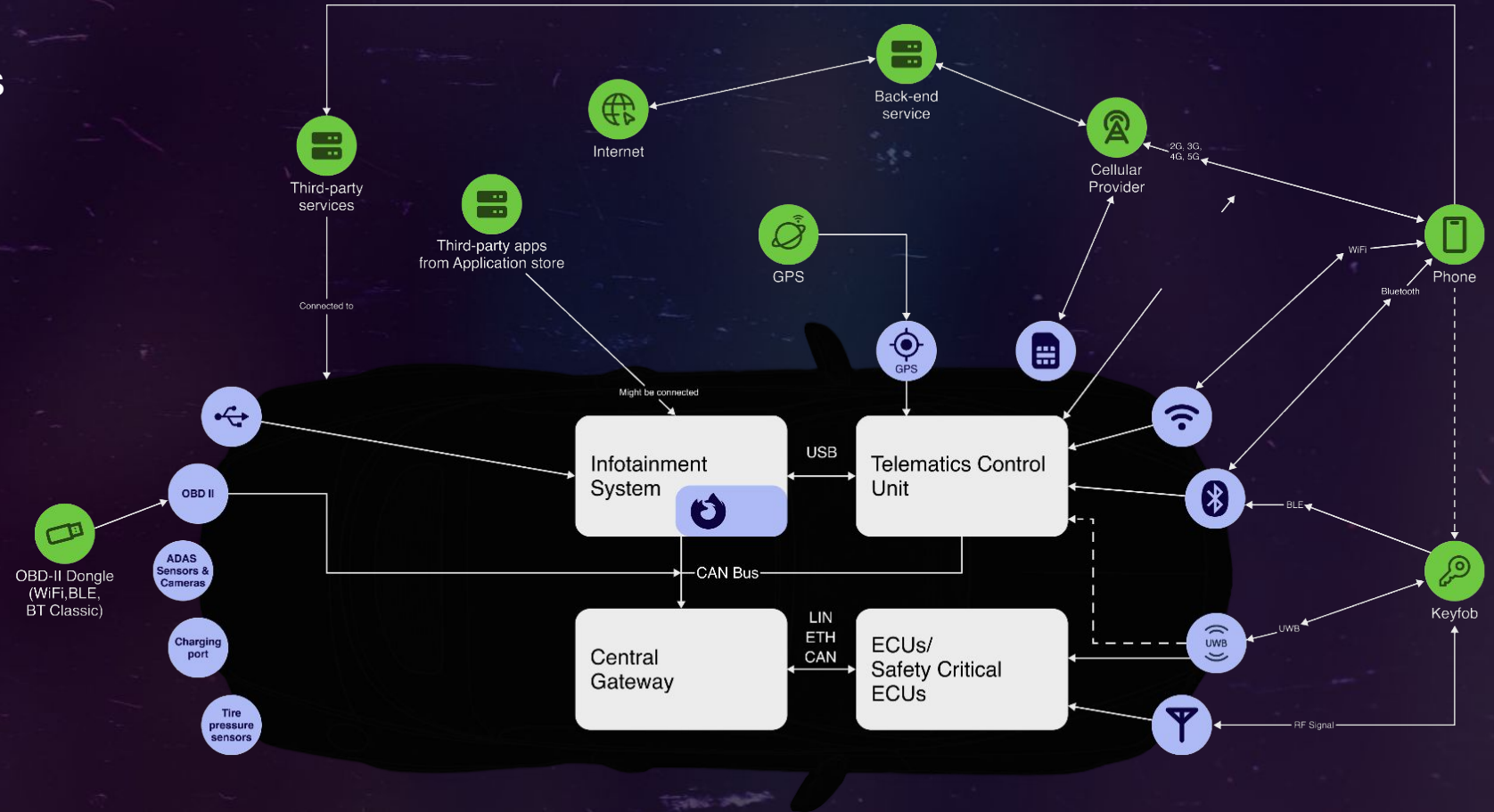
The cars definitely all have Bluetooth.



Scope

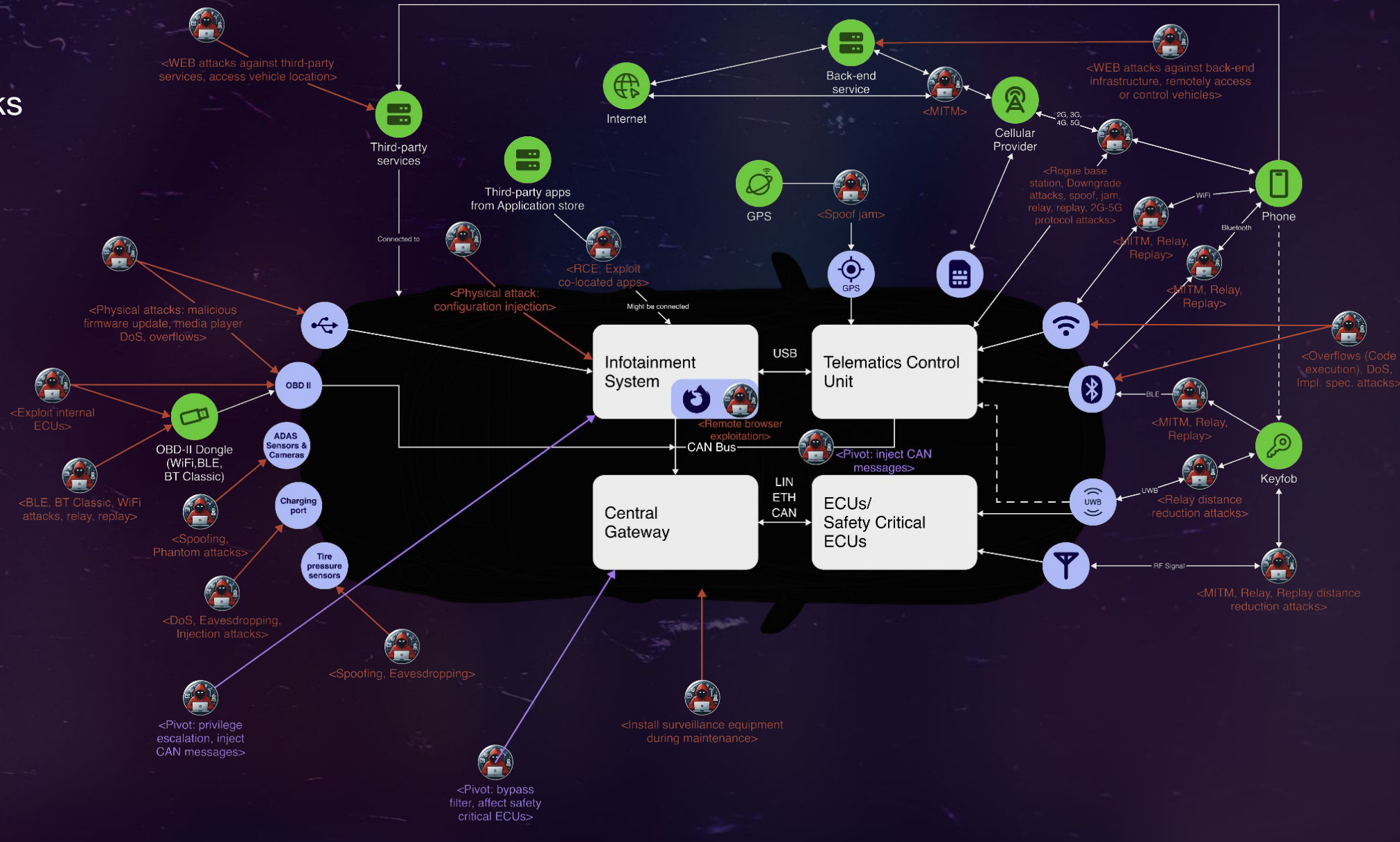
Cars are complex systems

- Interconnected networks of IoT
 - issues cannot be resolved
 - require recalls
- 19+ interfaces
- Rich connectivity



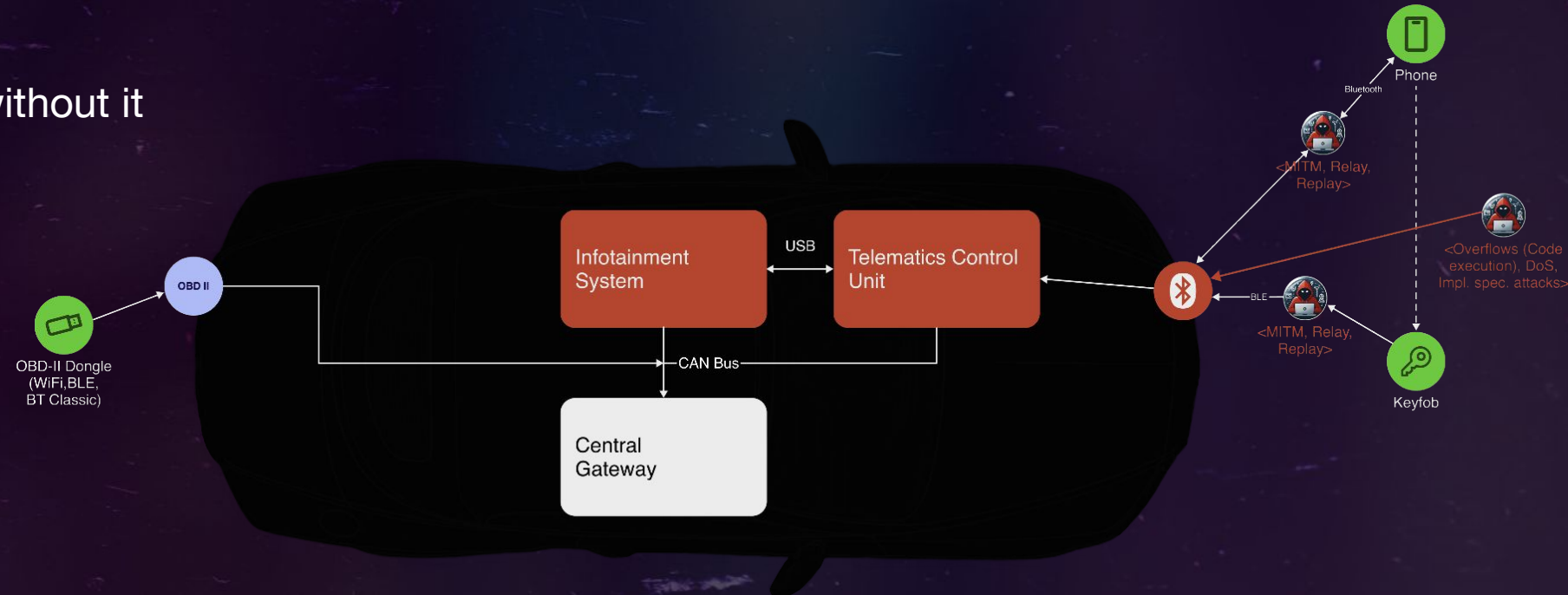
- Hundreds of reported attacks
- Including:

- WEB techniques
- Browser attacks
- Wireless attacks
- Physical attacks



Why Examine Bluetooth in Cars?

- 1 billion cars have Bluetooth (typically BT Classic)^{1,2}
- 87% of new cars have BT²
- Rich functionality
- Can't procure your car without it



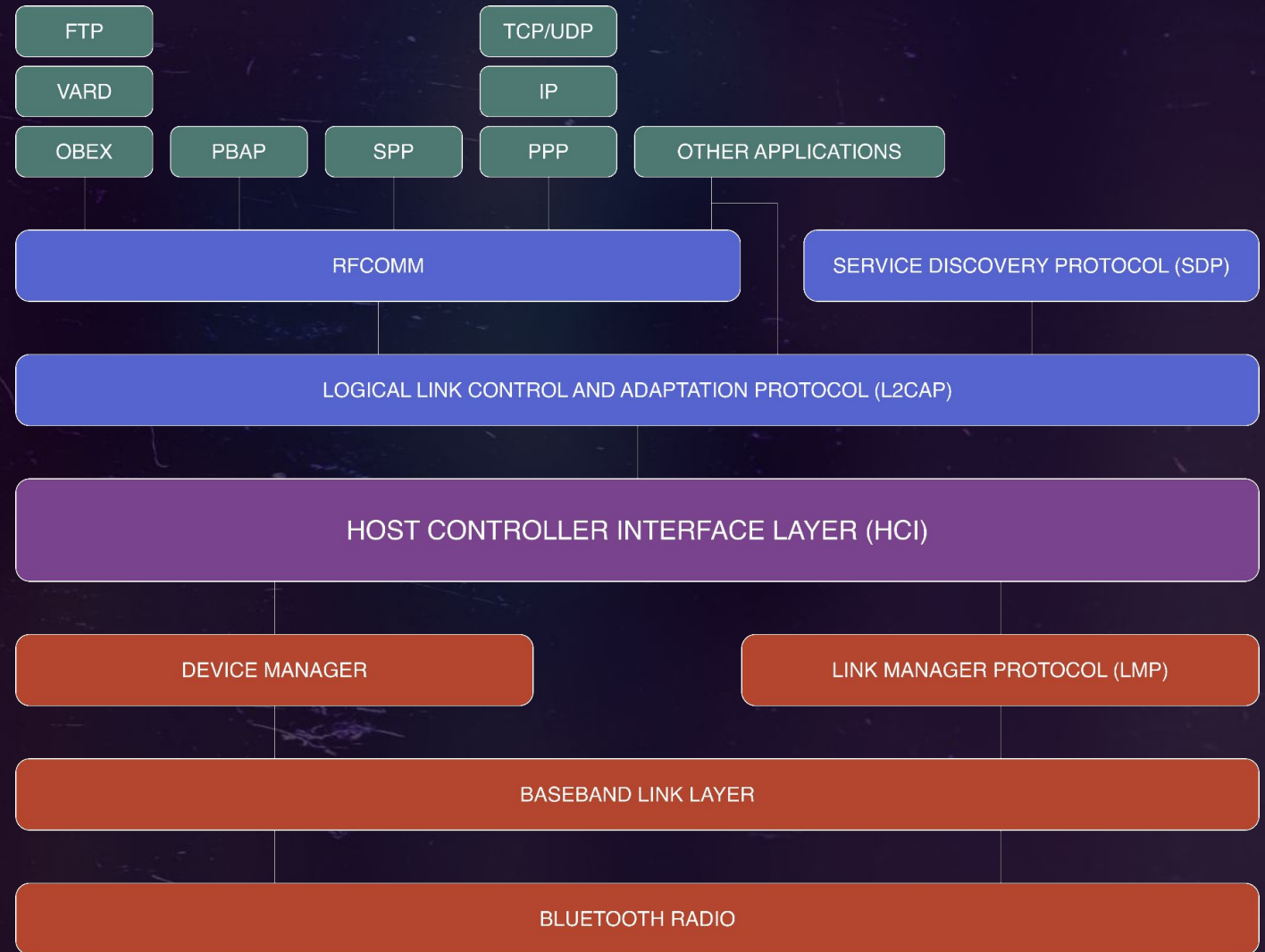
Most importantly: Nobody has done it yet!



Bluetooth and Vulnerability Testing Framework

II - Bluetooth - Shared responsibility

- Short-range wireless comm. Standard
- Complexity due to shared responsibility
 - errors
 - misunderstandings
- We are going to talk only about Bluetooth Classic
- Transport + Functionality



II - Bluetooth Profiles

- HFP
 - making calls
- A2DP
 - Transferring audio
- PBAP
 - extracting contacts
- MAP
 - extracting messages (Car kit profile)
- SAP
 - full access to the SIM card (Car kit profile)
 - Used in older cars
- FTP
 - file transfer
- HID
 - Human interface devices such as Keyboard, pointers, etc.



II - Bluetooth Security Model - Capabilities



DisplayYesNo



DisplayOnly



KeyboardOnly



NoInputNoOutput

II - Bluetooth Security Model

- “Everything or Nothing”
- Pairing modes
 - Legacy pairing
 - No SSP or SC
 - Just works
 - NiNo MitM
 - Passkey Entry
 - Method Confusion MitM
 - Numeric Comparison
 - The only secure option*

		INITIATOR			
RESPONDER		DisplayOnly	DisplayYesNo	KeyboardOnly	NoInputNoOutput
	DisplayOnly	Just Works	Just Works	Passkey Entry	Just Works
	DisplayYesNo	Just Works	Numeric Comparison	Passkey Entry	Just Works
	KeyboardOnly	Passkey Entry	Passkey Entry	Passkey Entry	Just Works
	NoInputNoOutput	Just Works	Just Works	Just Works	Just Works

II - Bluetooth Security Model

- “Everything or Nothing”
- Pairing modes
 - Legacy pairing
 - No SSP or SC
 - Just works
 - NiNo MitM
 - Passkey Entry
 - Method Confusion MitM
 - Numeric Comparison
 - The only secure option*

		INITIATOR			
RESPONDER		DisplayOnly	DisplayYesNo	KeyboardOnly	NoInputNoOutput
	DisplayOnly	Just Works	Just Works	Passkey Entry	Just Works
	DisplayYesNo	Just Works	Numeric Comparison	Passkey Entry	Just Works
	KeyboardOnly	Passkey Entry	Passkey Entry	Passkey Entry	Just Works
	NoInputNoOutput	Just Works	Just Works	Just Works	Just Works

II - Bluetooth Security Model

- “Everything or Nothing”
- Pairing modes
 - Legacy pairing
 - No SSP or SC
 - Just works
 - NiNo MitM
 - Passkey Entry
 - Method Confusion MitM
 - Numeric Comparison
 - The only secure option*

		INITIATOR			
RESPONDER		DisplayOnly	DisplayYesNo	KeyboardOnly	NoInputNoOutput
	DisplayOnly	Just Works	Just Works	Passkey Entry	Just Works
	DisplayYesNo	Just Works	Numeric Comparison	Passkey Entry	Just Works
	KeyboardOnly	Passkey Entry	Passkey Entry	Passkey Entry	Just Works
	NoInputNoOutput	Just Works	Just Works	Just Works	Just Works

II - Bluetooth Security Model

- “Everything or Nothing”
- Pairing modes
 - Legacy pairing
 - No SSP or SC
 - Just works
 - NiNo MitM
 - Passkey Entry
 - Method Confusion MitM
 - Numeric Comparison
 - The only secure option*

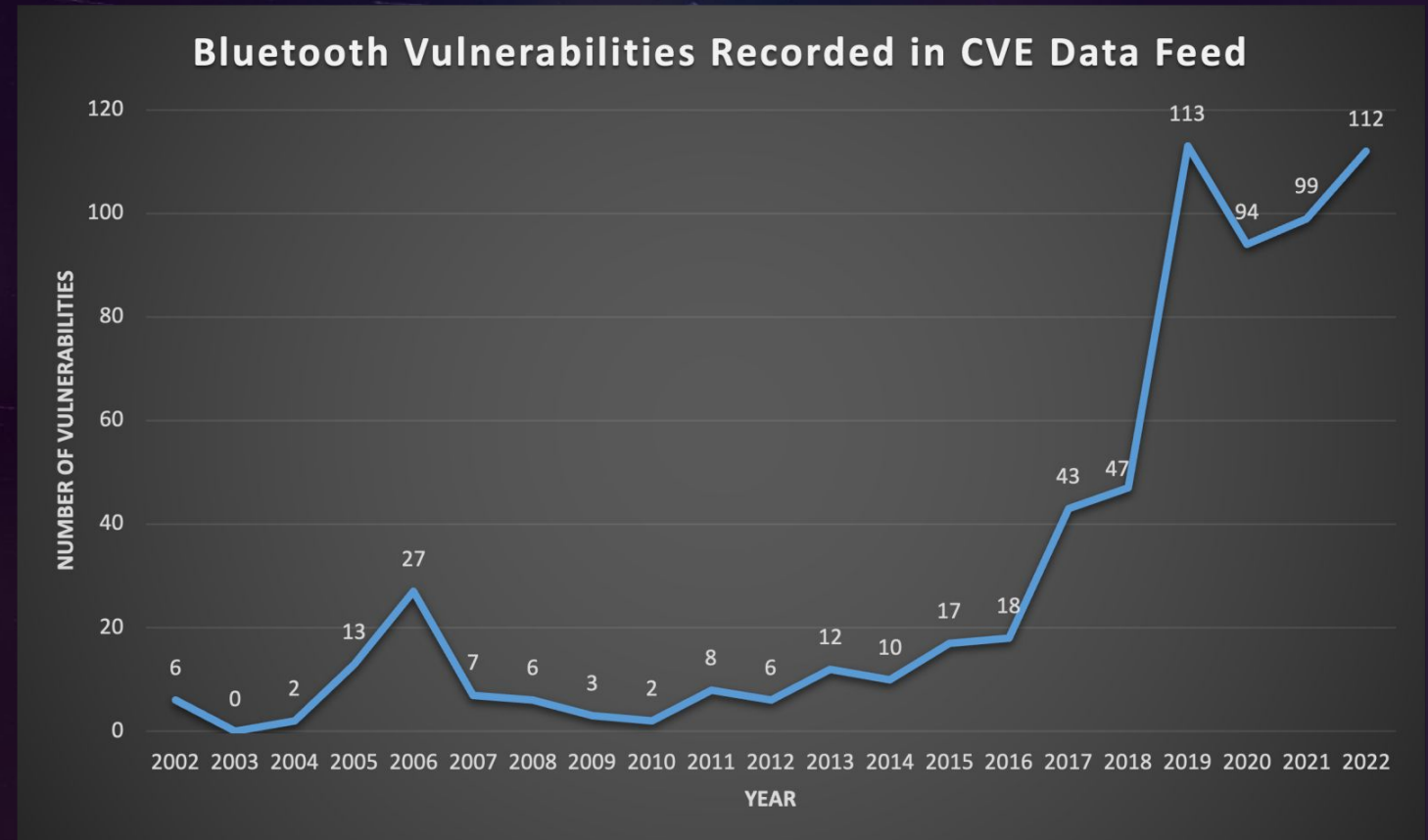
		INITIATOR			
RESPONDER		DisplayOnly	DisplayYesNo	KeyboardOnly	NoInputNoOutput
	DisplayOnly	Just Works	Just Works	Passkey Entry	Just Works
	DisplayYesNo	Just Works	Numeric Comparison	Passkey Entry	Just Works
	KeyboardOnly	Passkey Entry	Passkey Entry	Passkey Entry	Just Works
	NoInputNoOutput	Just Works	Just Works	Just Works	Just Works

- Once established there is no difference for profiles whether the secure pairing mode was used or not

II - Previous Research

- We found more than 108 attacks on Bluetooth standards (March 2024)
- 647 CVEs related to Bluetooth devices¹ as of 2022
- Exploit categories:
 - Critical
 - Remote Code Execution
 - Memory leakage
 - Man-in-the-middle
 - Denial of Service
 - Chaining
 - Not vulnerabilities
 - Weaknesses/Environment that helps with further exploitation

Source: SANS a Survey of Bluetooth Vulnerabilities Trends

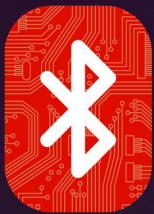


III - Bluetooth Testing Challenges

- General
 - Lacked a common database of Bluetooth vulnerabilities
 - Lacked a framework for testing
 - The PoCs are not shared or scattered across the Internet
 - Based on old hardware difficult to procure
- Testing
 - Black-box DoS-based BC testing - false positives and false negatives
 - Automation is difficult due to DoS attacks being too effective for some devices (for example restarting a car takes ages)

III - BlueToolkit

- Building on top of previous research
 - Collected and developed 44 exploits
 - Reproducibility
- Balance
 - Automation
 - Semi-automation
 - Manual
- Evaluation



BlueToolkit

<https://github.com/sgxgsx/BlueToolkit>



III - How it works





Attacking Cars

IV - Setting up BlueToolkit

- Ubuntu-based laptop or VM
- USB cables C/Micro USB
- ESP-WROVER-KIT-VE -> \$50
- Nexus 5 phone -> CYW20735 -> \$50
- 1-3 hours per car
- Engine should be started (safety!)
- Observe In-Vehicle Infotainment (IVI) logs if you can



IV - Procuring cars

- All provided by
 - Cyber-Defence Campus
 - Army logistics
 - Friends
- 22 cars
 - 18 fully tested
 - 4 partially
- Price range from ~\$10k to ~\$120k
- 60%¹ of the global market by vehicle sales
 - 12/15 top manufacturers in 2023¹
- All BlueToolkit tests are non-invasive



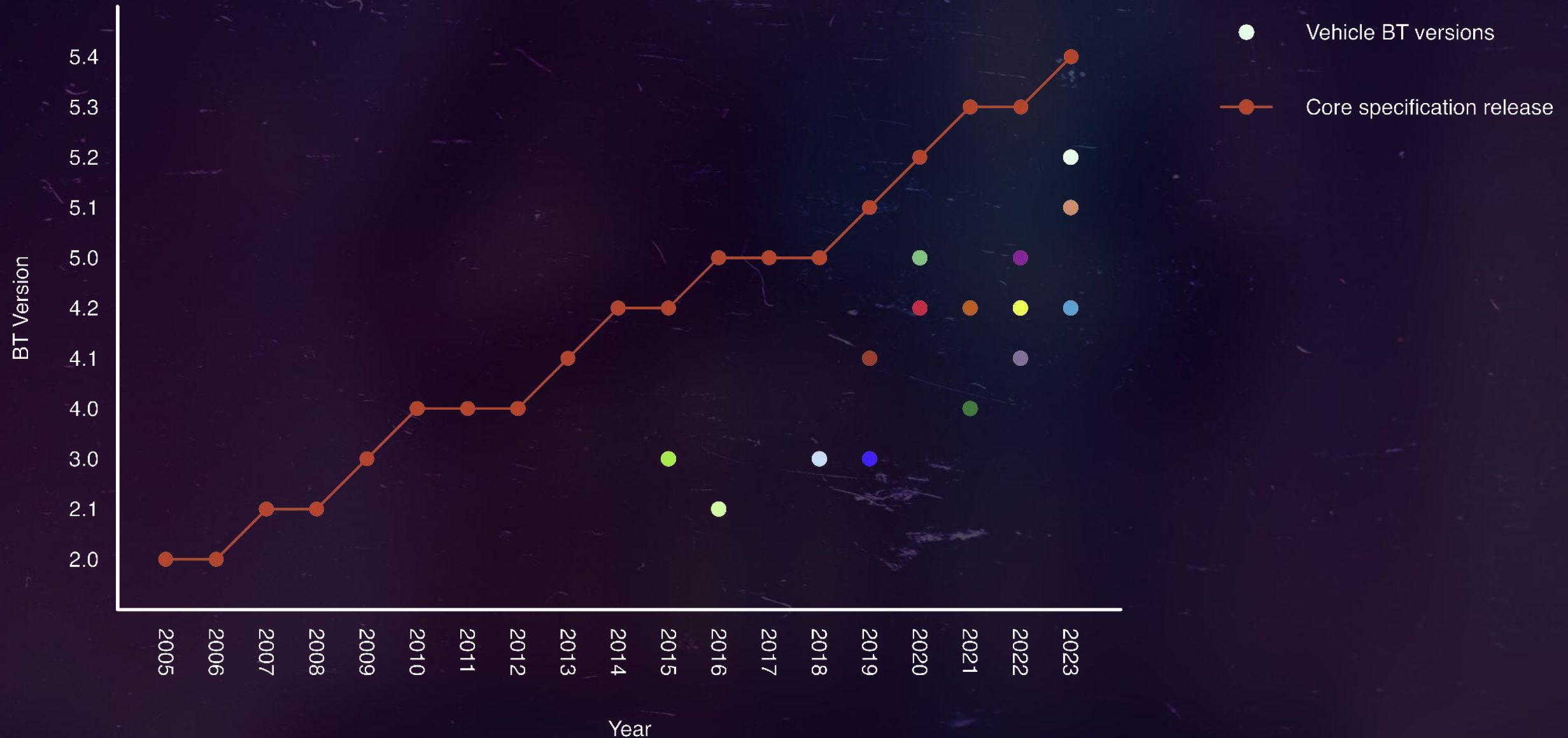
1. <https://www.factorywarrantylist.com/car-sales-by-manufacturer.html>

IV - Testing results: Overview

- ~40 hours spent
- 73 vulnerabilities found
 - Some issues are not possible to solve
 - Inherent issues
- 64/73 reported
- All vulnerabilities were reported responsibly

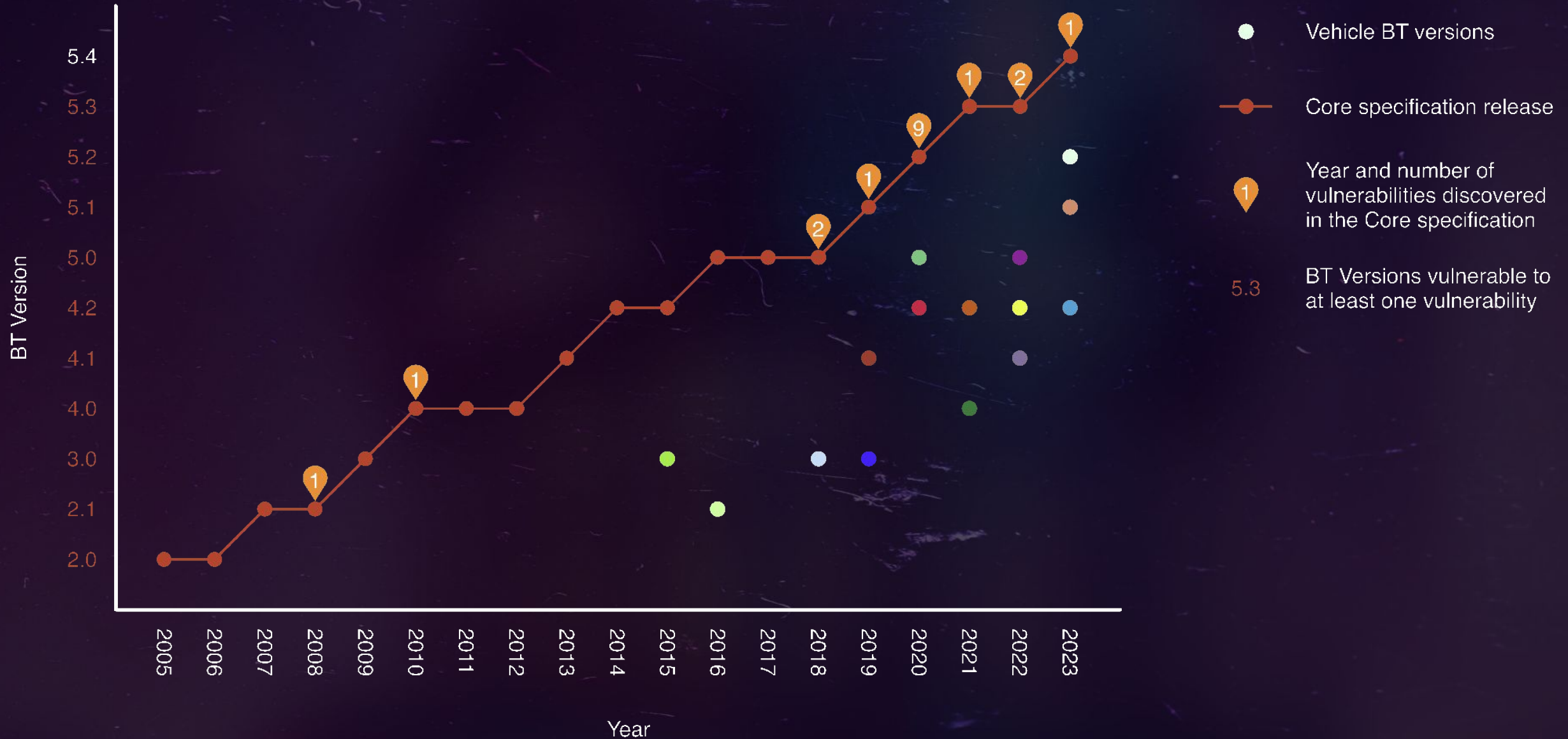


IV - Cars lag in adoption of the newest BT standards



Mean - 7 years, Average - 7 years. Min - 3 years, Max - 11 years. Std = 1.5 years

IV - Cars lag in adoption of the newest BT standards



Mean - 7 years, Average - 7 years. Min - 3 years, Max - 11 years. Std = 1.5 years

IV - Full results of our car tests

	VEHICLE	YEAR	TESTED	VULNS	CRITICAL	MITM	DOS	CHAIN
	Tesla Model Y	2023	44	1	0	1	0	0
	VW Caddy	2023	44	0	0	0	0	3
	Toyota Corolla	2023	44	8	0	0	8	1
	Mini Cooper	2022	44	4	0	2	2	3
	VW T6.1	2022	44	5	1	4	0	4
	Skoda Octavia	2022	44	0	0	0	0	2
	VW ID.3 Pro	2022	44	1	0	1	0	2
	Hyundai Kona	2022	44	1	0	1	0	4
	Renault Megane	2021	44	10	1	2	7	3
	Sprinter 316CDI	2021	44	1	0	0	1	3
	BMW X2	2021	44	7	0	4	3	3
	Renault ZOE	2021	44	5	1	3	1	3
	Audi E-TRON	2020	44	1	0	1	0	3
	Audi A5	2020	44	3	0	2	1	3
	Honda e	2020	44	4	0	4	0	3
	Opel Astra	2019	44	4	1	0	3	2
	Chevrolet Corvette	2018	44	4	0	2	2	3
	Renault Megane	2016	44	7	0	6	1	3
Partially tested	Skoda Enyaq	2023	29	0	0	0	0	0
	Polestar 2	2022	31	1	0	0	1	1
	Skoda Octavia	2019	28	2	0	2	0	1
	Skoda Octavia	2015	7	4	2	2	0	2

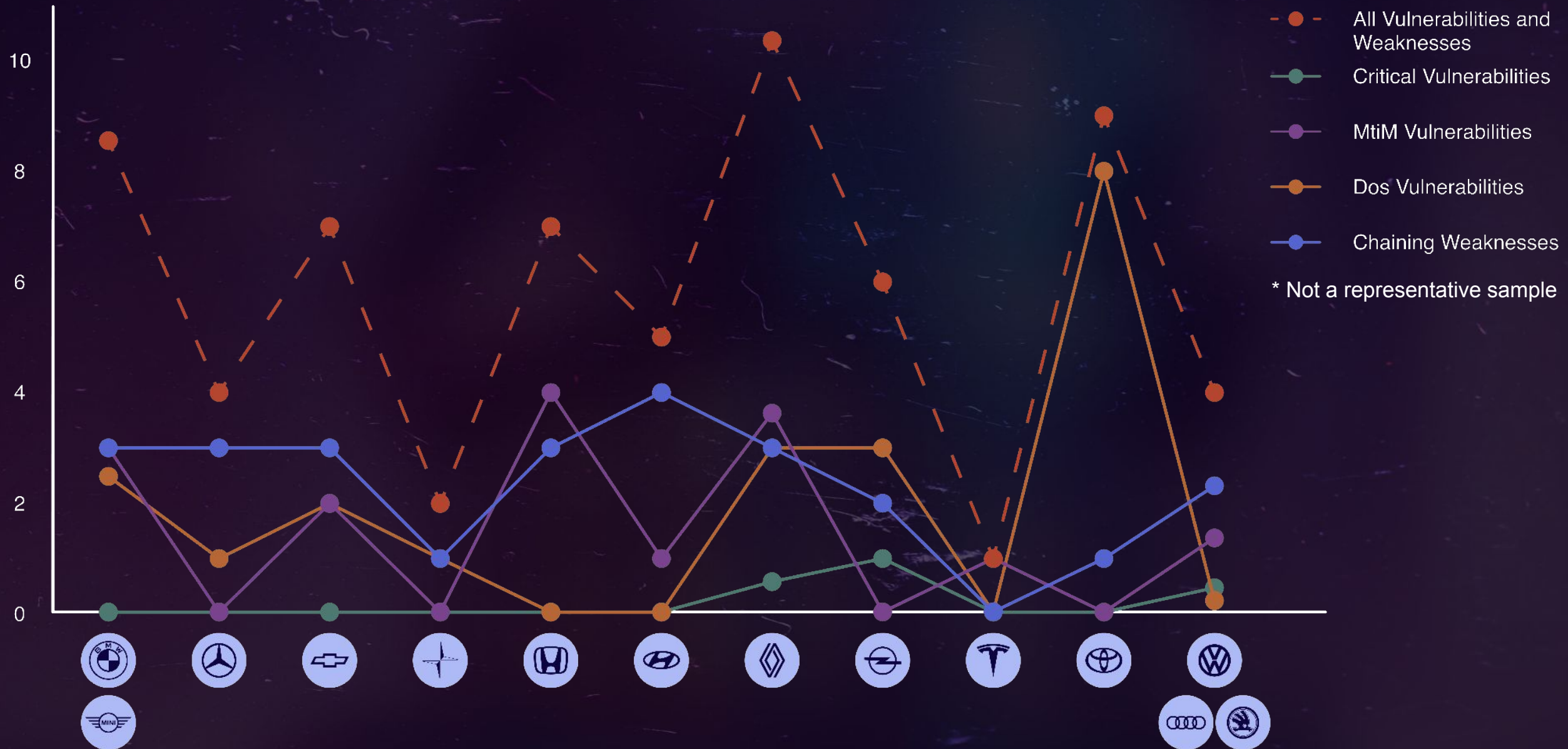
IV - Full results of our car tests

	VEHICLE	YEAR	TESTED	VULNS	CRITICAL	MITM	DOS	CHAIN
	Tesla Model Y	2023	44	1	0	1	0	0
	VW Caddy	2023	44	0	0	0	0	3
	Toyota Corolla	2023	44	8	0	0	8	1
	Mini Cooper	2022	44	4	0	2	2	3
	VW T6.1	2022	44	5	1	4	0	4
	Skoda Octavia	2022	44	0	0	0	0	2
	VW ID.3 Pro	2022	44	1	0	1	0	2
	Hyundai Kona	2022	44	1	0	1	0	4
	Renault Megane	2021	44	10	1	2	7	3
	Sprinter 316CDI	2021	44	1	0	0	1	3
	BMW X2	2021	44	7	0	4	3	3
	Renault ZOE	2021	44	5	1	3	1	3
	Audi E-TRON	2020	44	1	0	1	0	3
	Audi A5	2020	44	3	0	2	1	3
	Honda e	2020	44	4	0	4	0	3
	Opel Astra	2019	44	4	1	0	3	2
	Chevrolet Corvette	2018	44	4	0	2	2	3
	Renault Megane	2016	44	7	0	6	1	3
Partially tested	Skoda Enyaq	2023	29	0	0	0	0	0
	Polestar 2	2022	31	1	0	0	1	1
	Skoda Octavia	2019	28	2	0	2	0	1
	Skoda Octavia	2015	7	4	2	2	0	2

IV - Full results of our car tests

	VEHICLE	YEAR	TESTED	VULNS	CRITICAL	MITM	DOS	CHAIN
	Tesla Model Y	2023	44	1	0	1	0	0
	VW Caddy	2023	44	0	0	0	0	3
	Toyota Corolla	2023	44	8	0	0	8	1
	Mini Cooper	2022	44	4	0	2	2	3
	VW T6.1	2022	44	5	1	4	0	4
	Skoda Octavia	2022	44	0	0	0	0	2
	VW ID.3 Pro	2022	44	1	0	1	0	2
	Hyundai Kona	2022	44	1	0	1	0	4
	Renault Megane	2021	44	10	1	2	7	3
	Sprinter 316CDI	2021	44	1	0	0	1	3
	BMW X2	2021	44	7	0	4	3	3
	Renault ZOE	2021	44	5	1	3	1	3
	Audi E-TRON	2020	44	1	0	1	0	3
	Audi A5	2020	44	3	0	2	1	3
	Honda e	2020	44	4	0	4	0	3
	Opel Astra	2019	44	4	1	0	3	2
	Chevrolet Corvette	2018	44	4	0	2	2	3
	Renault Megane	2016	44	7	0	6	1	3
Partially tested	Skoda Enyaq	2023	29	0	0	0	0	0
	Polestar 2	2022	31	1	0	0	1	1
	Skoda Octavia	2019	28	2	0	2	0	1
	Skoda Octavia	2015	7	4	2	2	0	2

IV - Average number of vulnerabilities found per car per manufacturer



The plot shows an average number of vulnerabilities found per car for each manufacturer/alliance.CCC

IV - Average number of vulnerabilities found per car per manufacturer



The plot shows an average number of vulnerabilities found per car for each manufacturer/alliance.

IV - Average number of vulnerabilities found per car per manufacturer



The plot shows an average number of vulnerabilities found per car for each manufacturer/alliance.



Novel Attacks

V - Contact Extractor attack



MAC - AA:AA:AA:BB:BB:BB



Sniffing mode



Establish BT Connection



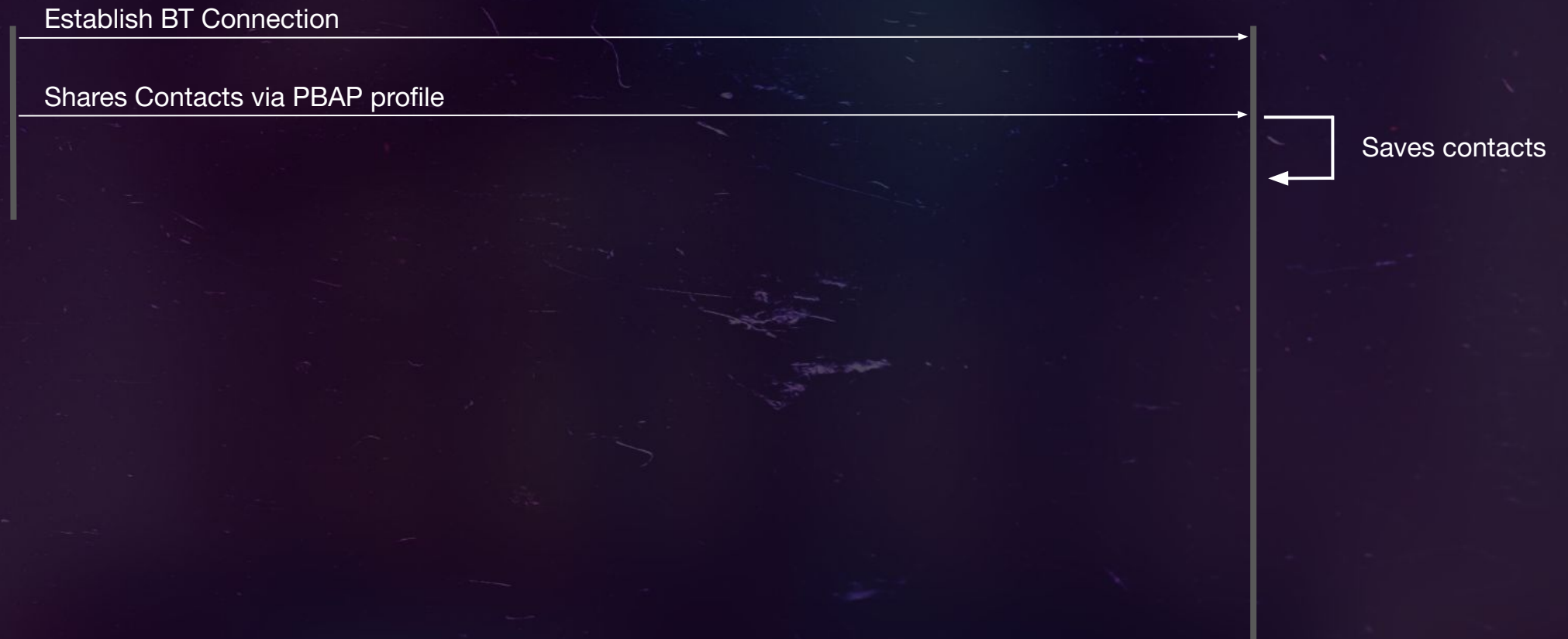
V - Contact Extractor attack



MAC - AA:AA:AA:BB:BB:BB



Sniffing mode



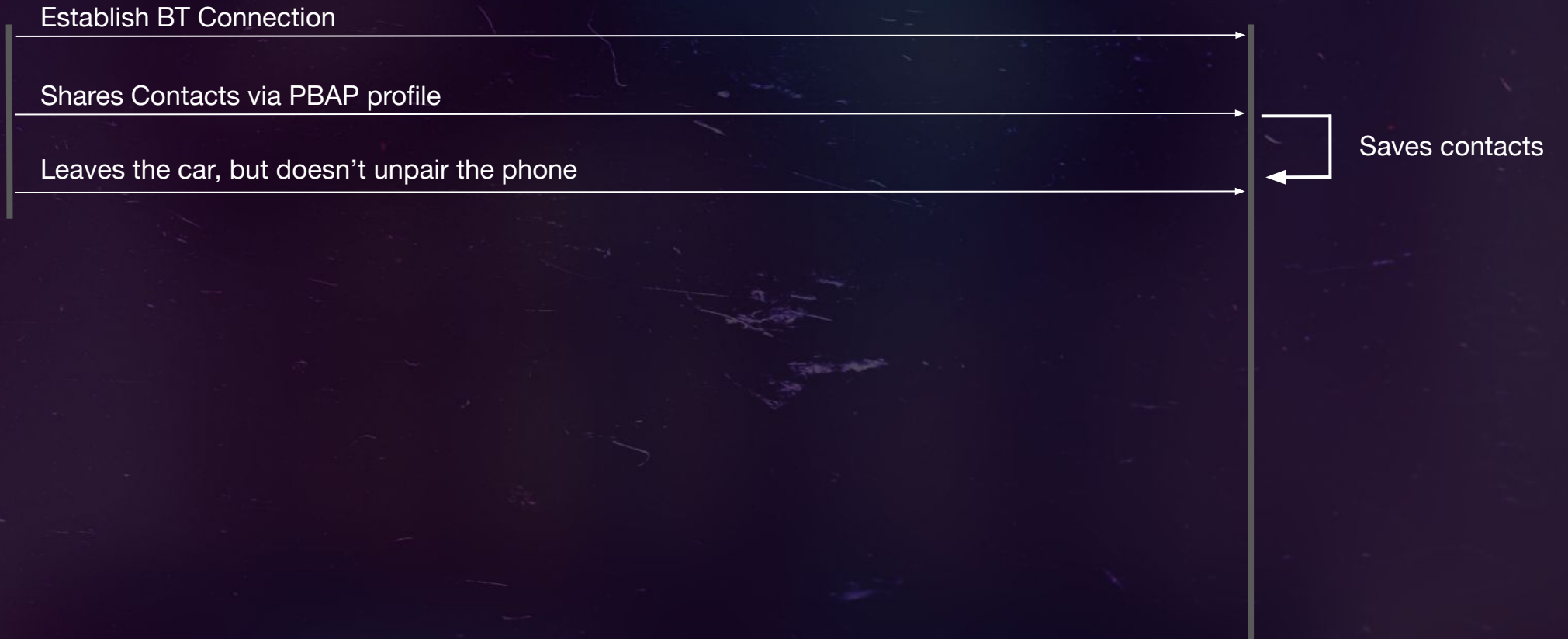
V - Contact Extractor attack



MAC - AA:AA:AA:BB:BB:BB



Sniffing mode



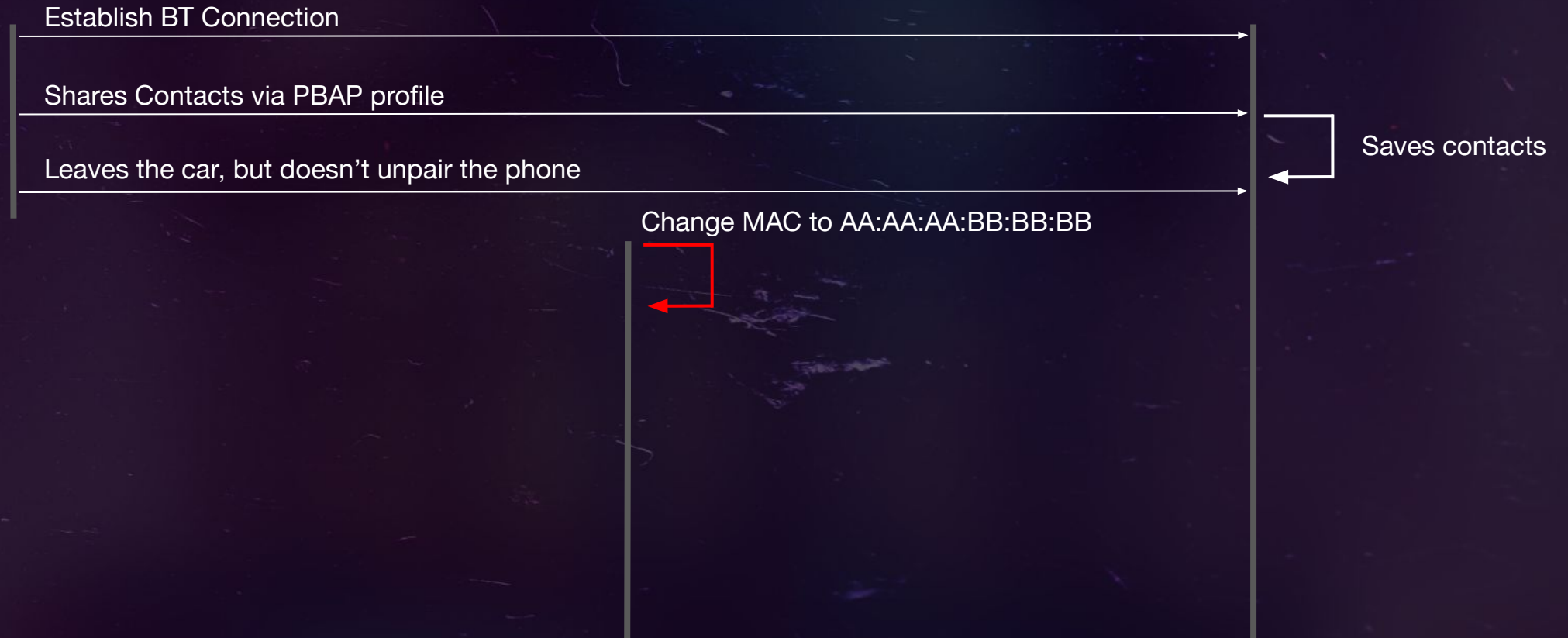
V - Contact Extractor attack



MAC - AA:AA:AA:BB:BB:BB



Sniffing mode



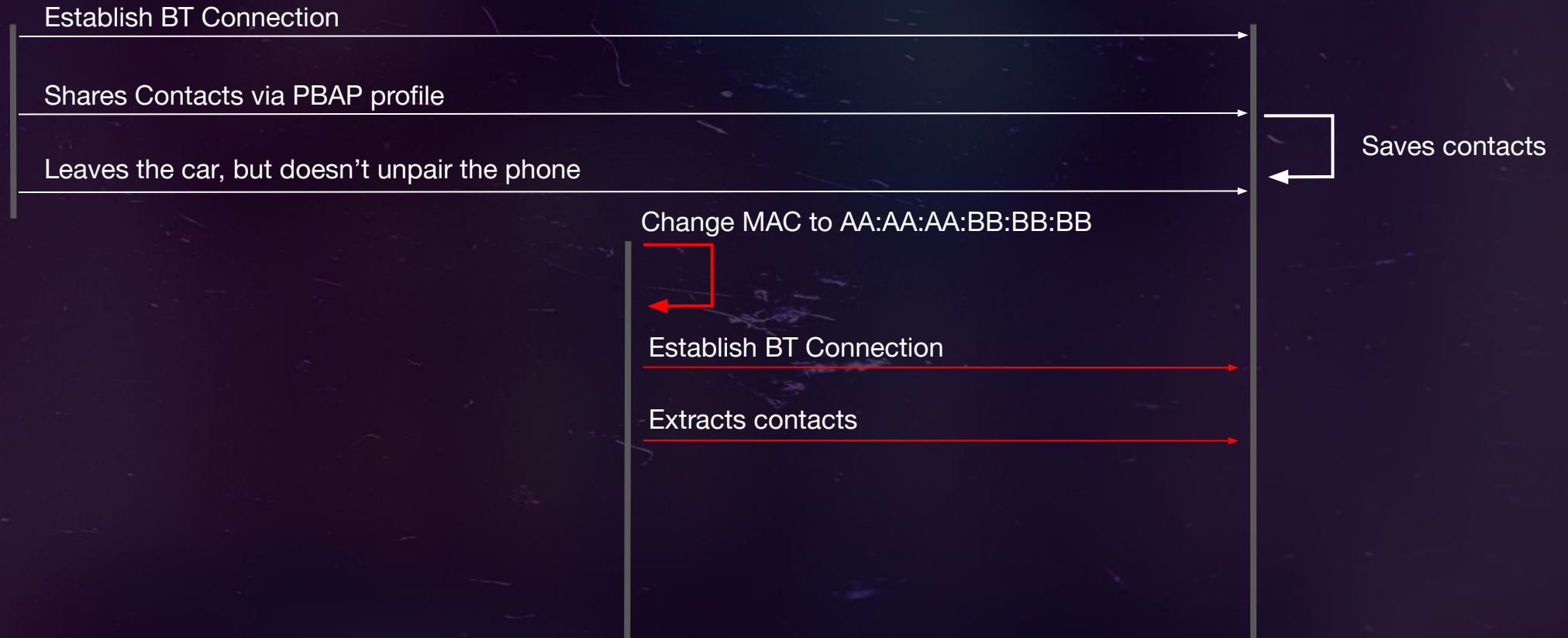
V - Contact Extractor attack



MAC - AA:AA:AA:BB:BB:BB



Sniffing mode



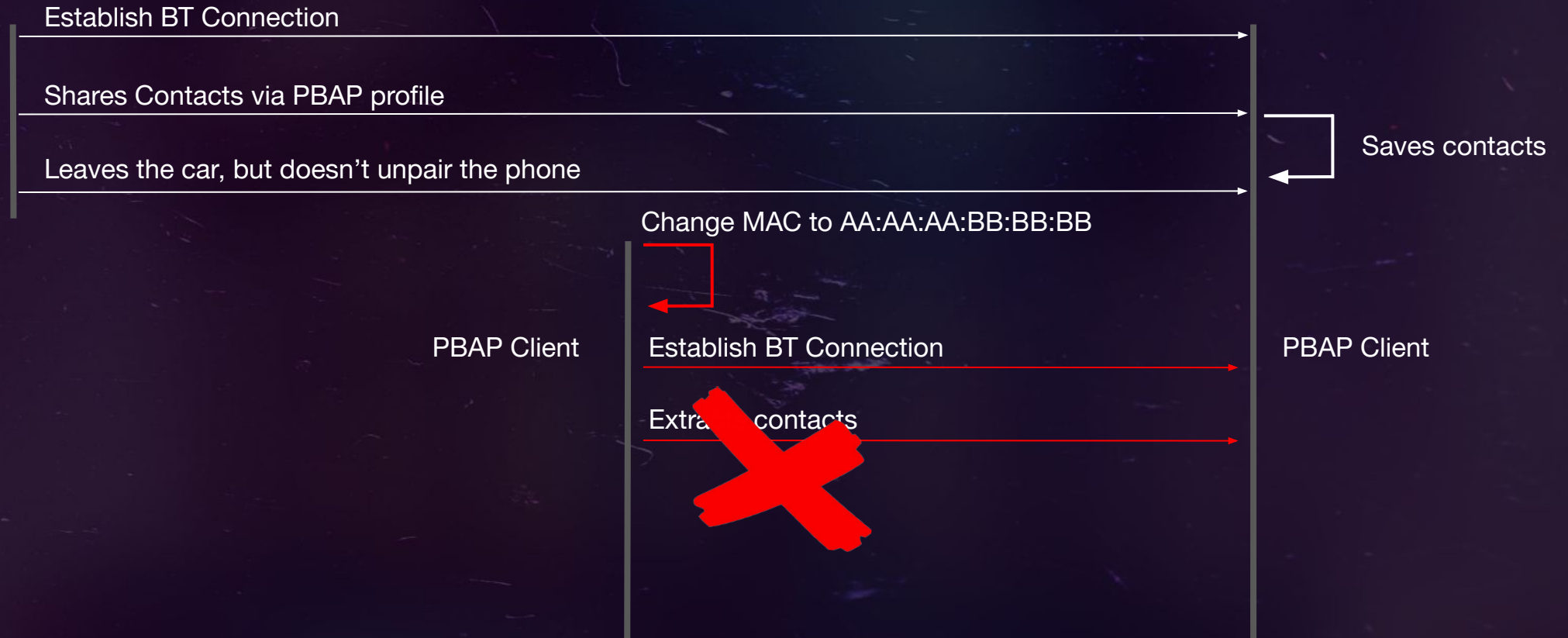
V - Contact Extractor attack



MAC - AA:AA:AA:BB:BB:BB



Sniffing mode



V - Contact Extractor attack



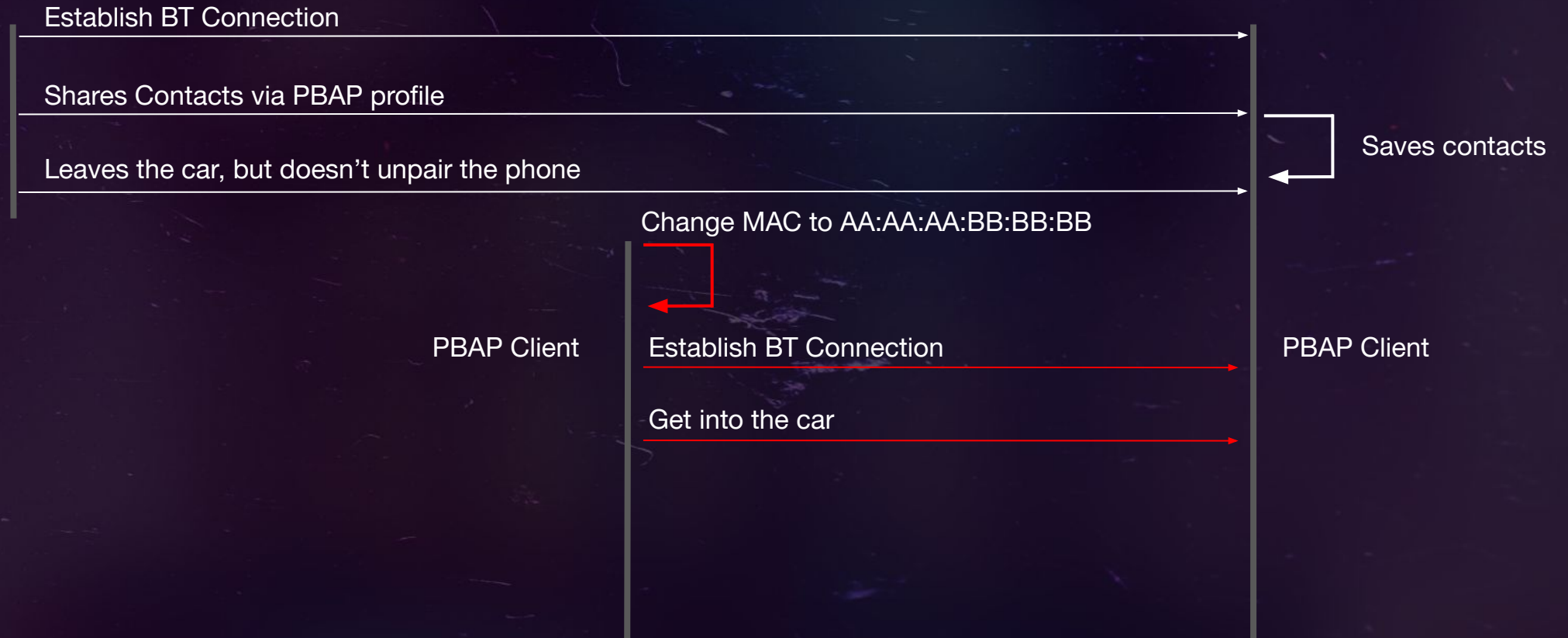
MAC - AA:AA:AA:BB:BB:BB



Sniffing mode



*Car sharing context



V - Contact Extractor attack



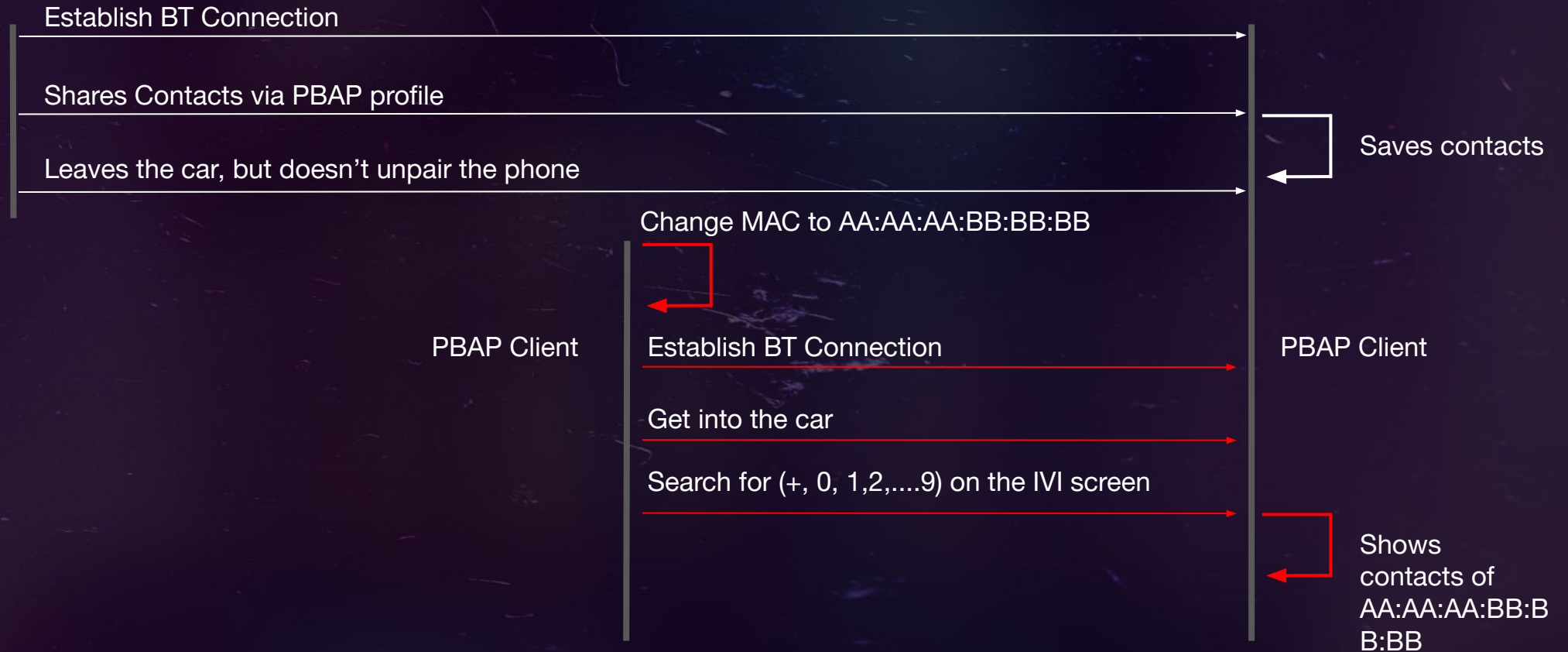
MAC - AA:AA:AA:BB:BB:BB



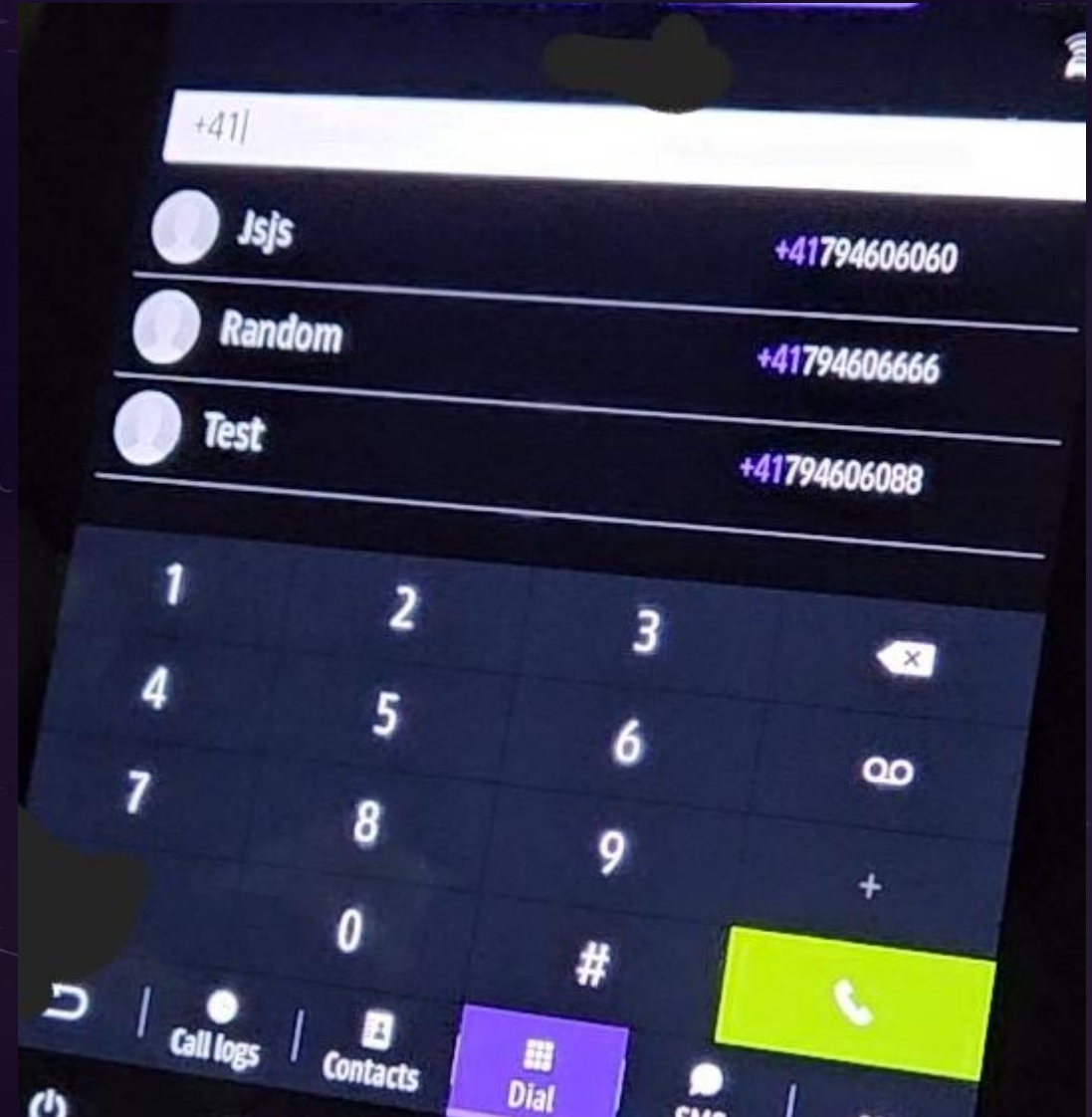
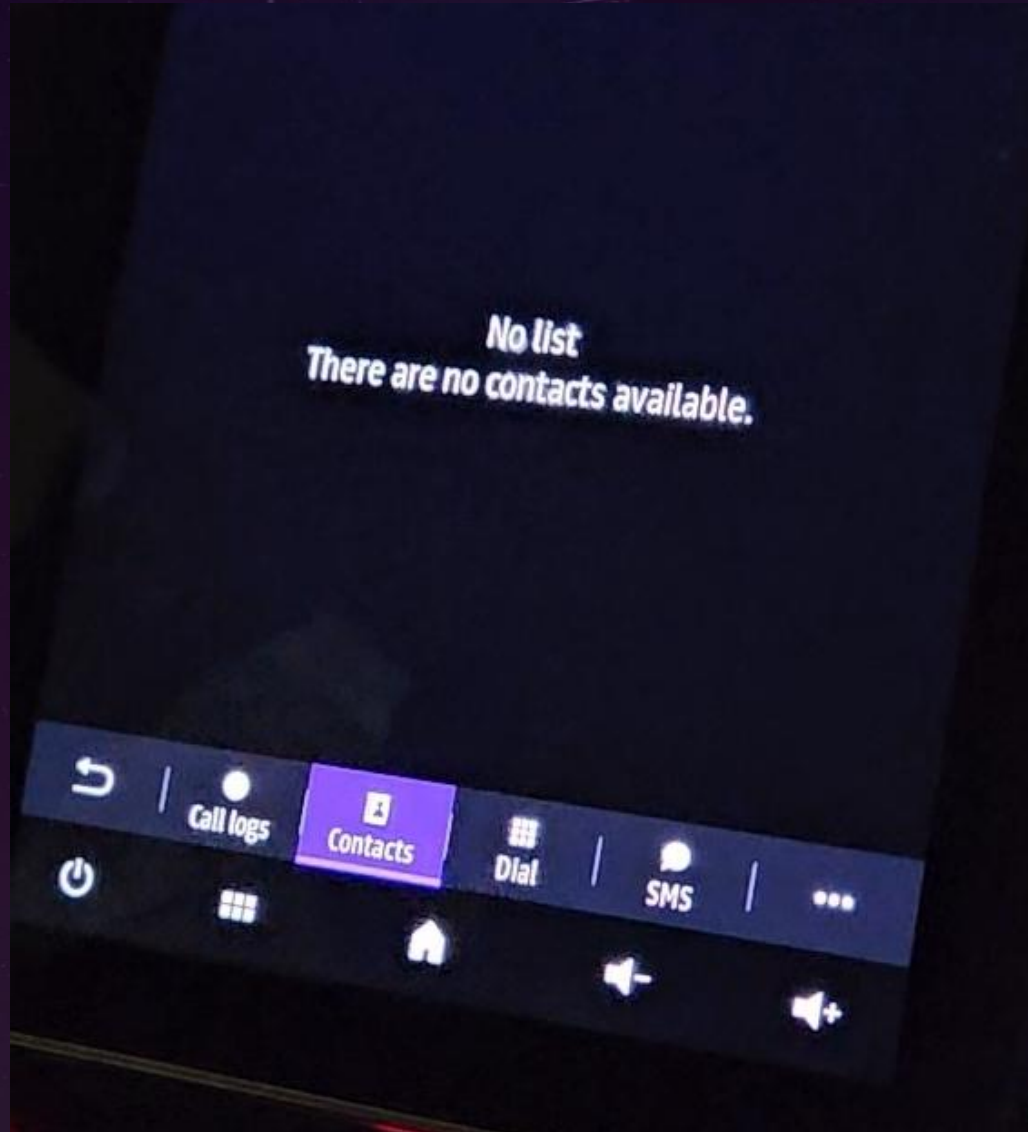
Sniffing mode



*Car sharing context



V - Contact Extractor attack



V - Vehicular NiNo MitM



AA:AA:AA:BB:BB:BB



Same name as CC:CC

NiNo io-cap

AA:AA:AA:BB:BB:BB

NiNo io-cap



CC:CC:CC:DD:DD:DD



V - Vehicular NiNo MitM



AA:AA:AA:BB:BB:BB



Same name as CC:CC

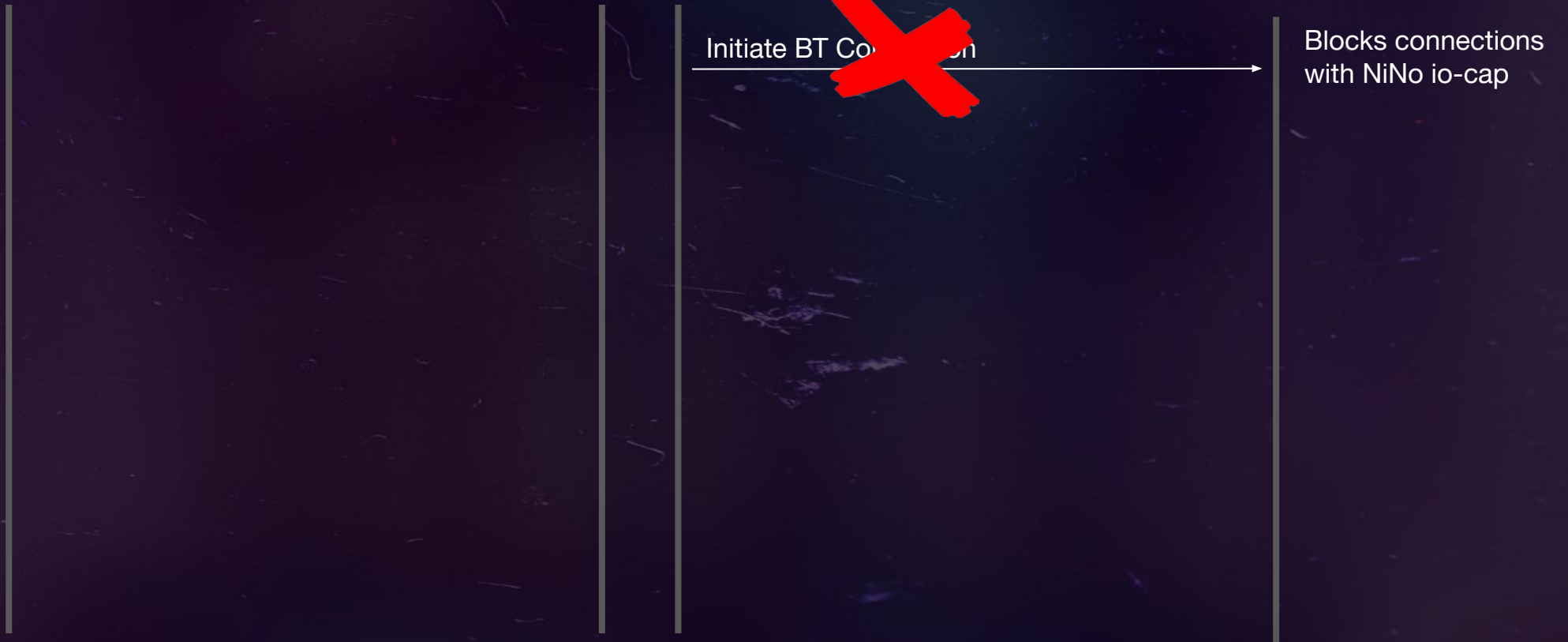
AA:AA:AA:BB:BB:BB

NiNo io-cap

NiNo io-cap



CC:CC:CC:DD:DD:DD



V - Vehicular NiNo MitM



AA:AA:AA:BB:BB:BB



Same name as CC:CC

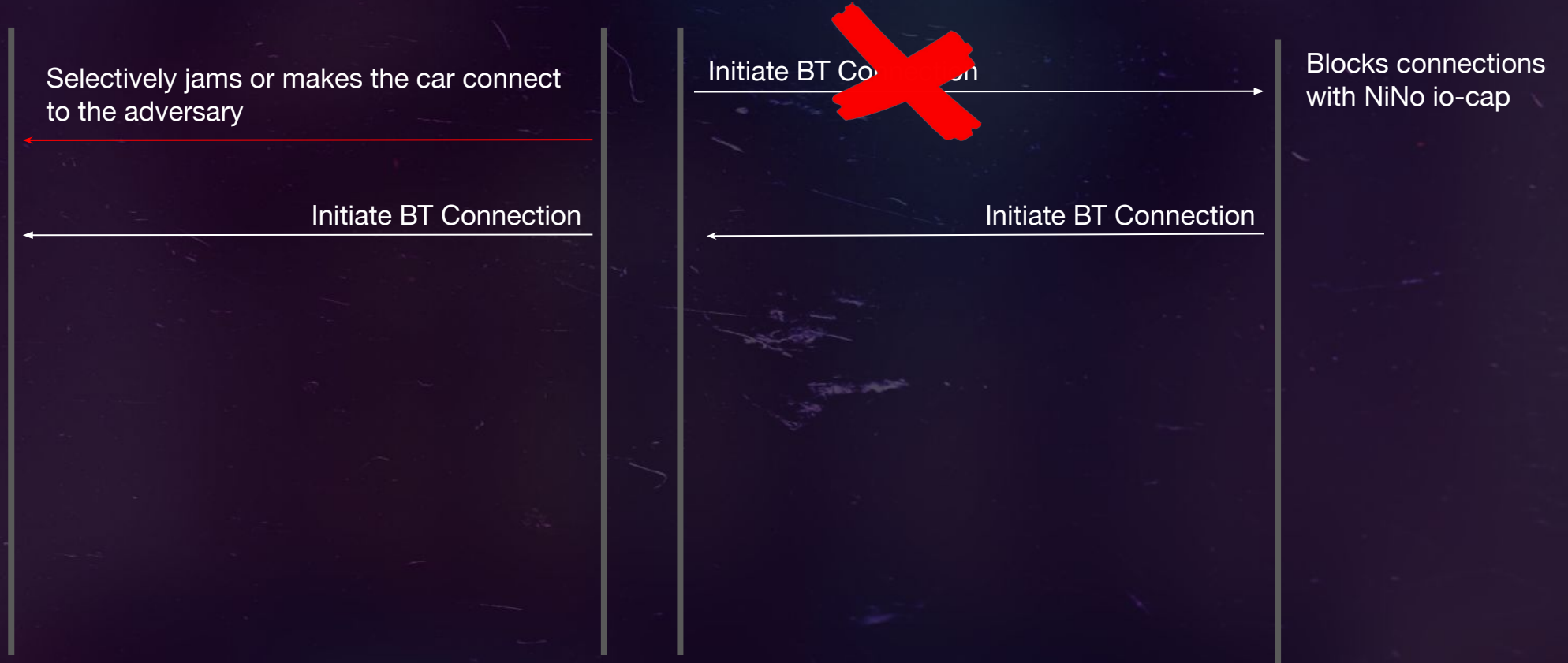
AA:AA:AA:BB:BB:BB

NiNo io-cap

NiNo io-cap



CC:CC:CC:DD:DD:DD



V - Vehicular NiNo MitM



AA:AA:AA:BB:BB:BB



Same name as CC:CC

AA:AA:AA:BB:BB:BB

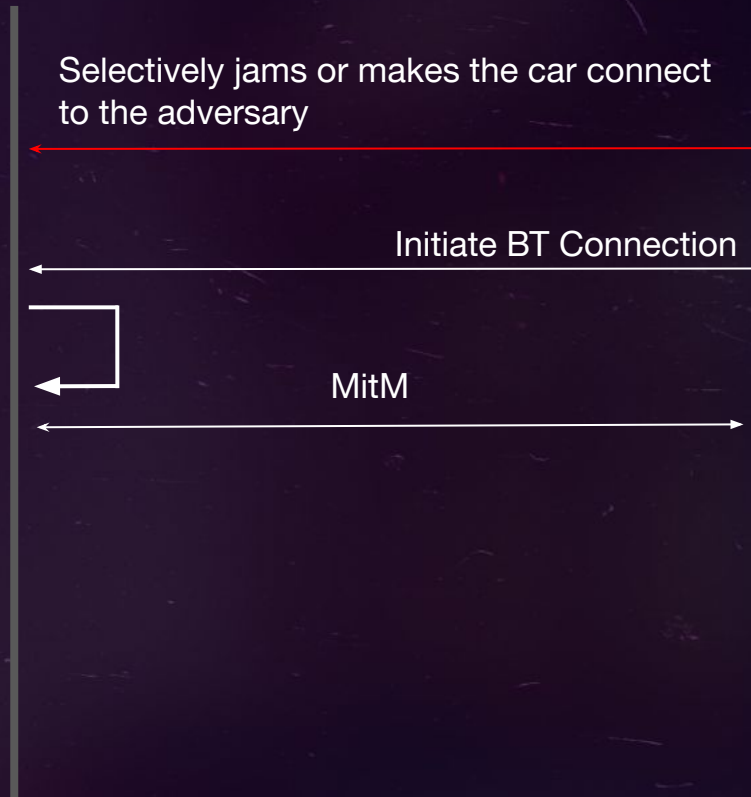
NiNo io-cap

NiNo io-cap



CC:CC:CC:DD:DD:DD

User confirms



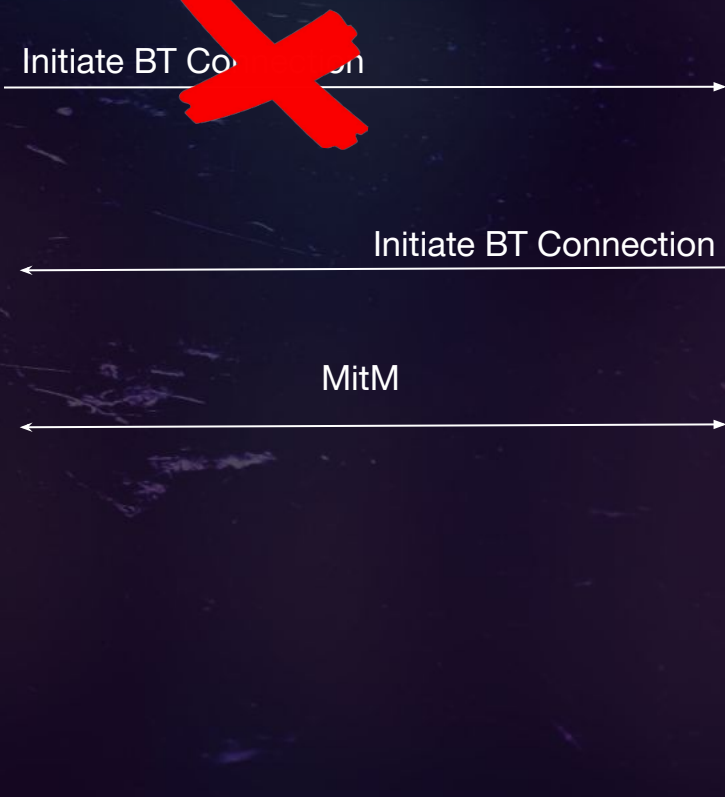
Initiate BT Connection

Initiate BT Connection

MitM

Blocks connections with NiNo io-cap

User confirms



V - Insecure NC MitM attack



AA:AA:AA:BB:BB:BB



Same name as CC:CC...

Same name as AA:AA...



CC:CC:CC:DD:DD:DD

NiNo io-cap

DisplayYesNo, KeyboardOnly,
DisplayOnly or NiNo io-cap

Initiate BT Connection

Expects connections
with DisplayYesNo io-cap
only or is just vulnerable

V - Insecure NC MitM attack



AA:AA:AA:BB:BB:BB



Same name as CC:CC...

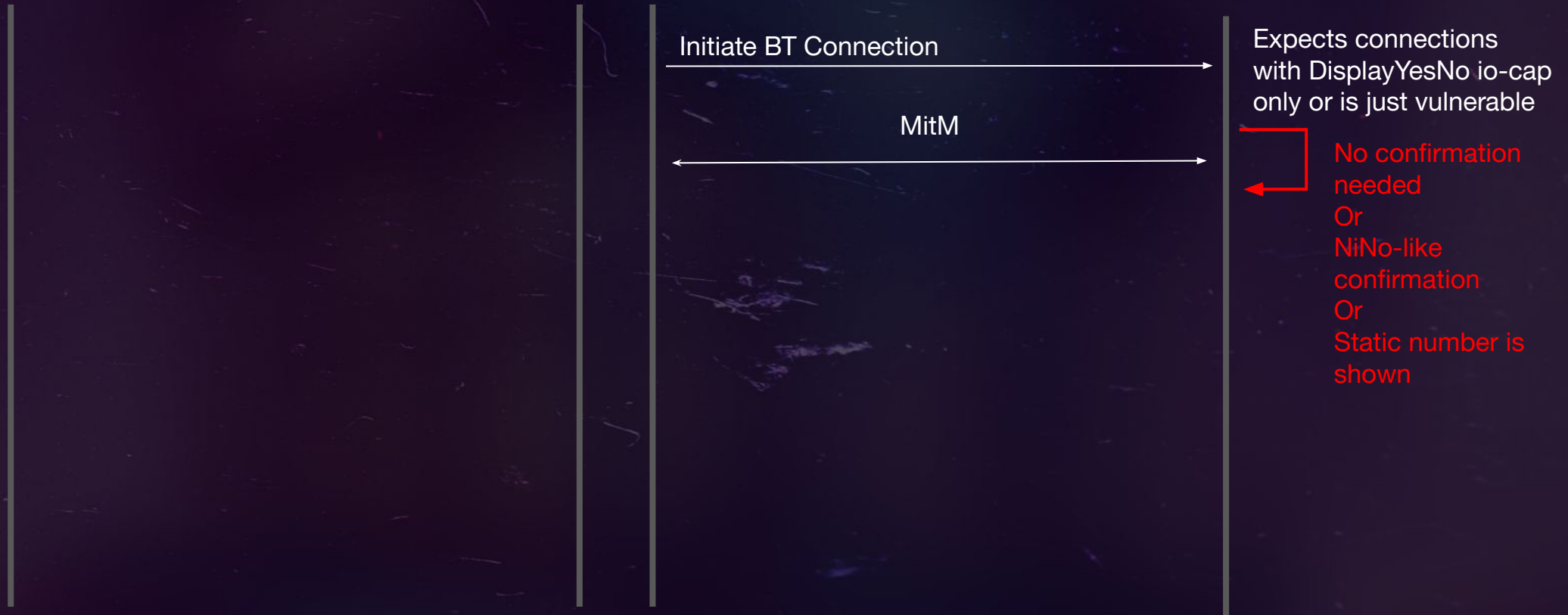
Same name as AA:AA...



CC:CC:CC:DD:DD:DD

NiNo io-cap

DisplayYesNo, KeyboardOnly,
DisplayOnly or NiNo io-cap



V - Insecure NC MitM attack



AA:AA:AA:BB:BB:BB



Same name as CC:CC...

Same name as AA:AA...



CC:CC:CC:DD:DD:DD

NiNo io-cap

DisplayYesNo, KeyboardOnly,
DisplayOnly or NiNo io-cap

User confirms

Initiate BT Connection

MitM

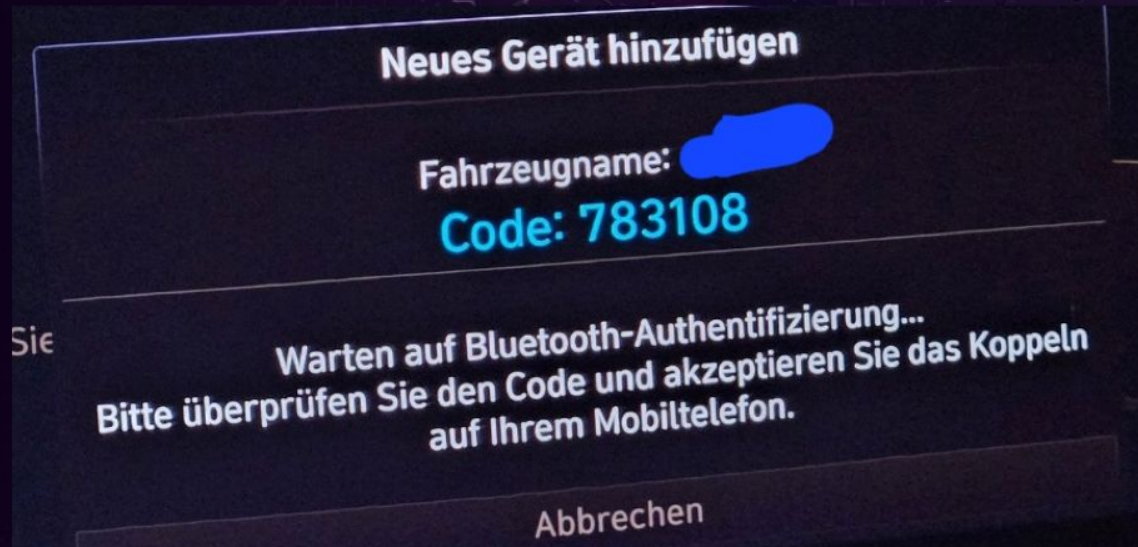
Initiate BT Connection

MitM

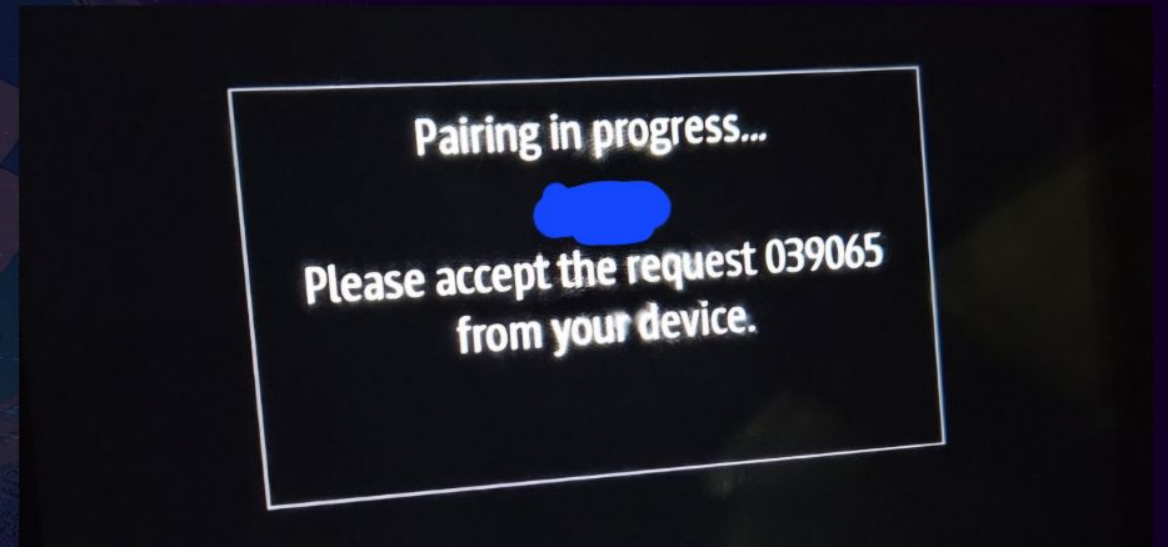
Expects connections
with DisplayYesNo io-cap
only or is just vulnerable

No confirmation
needed
Or
NiNo-like
confirmation
Or
Static number is
shown

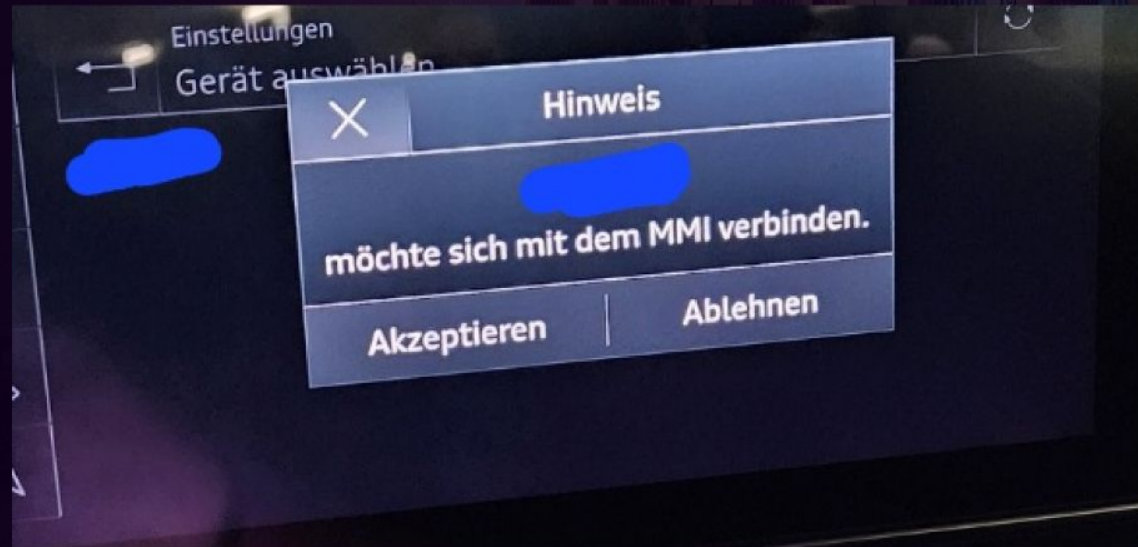
V - Insecure NC MitM attack



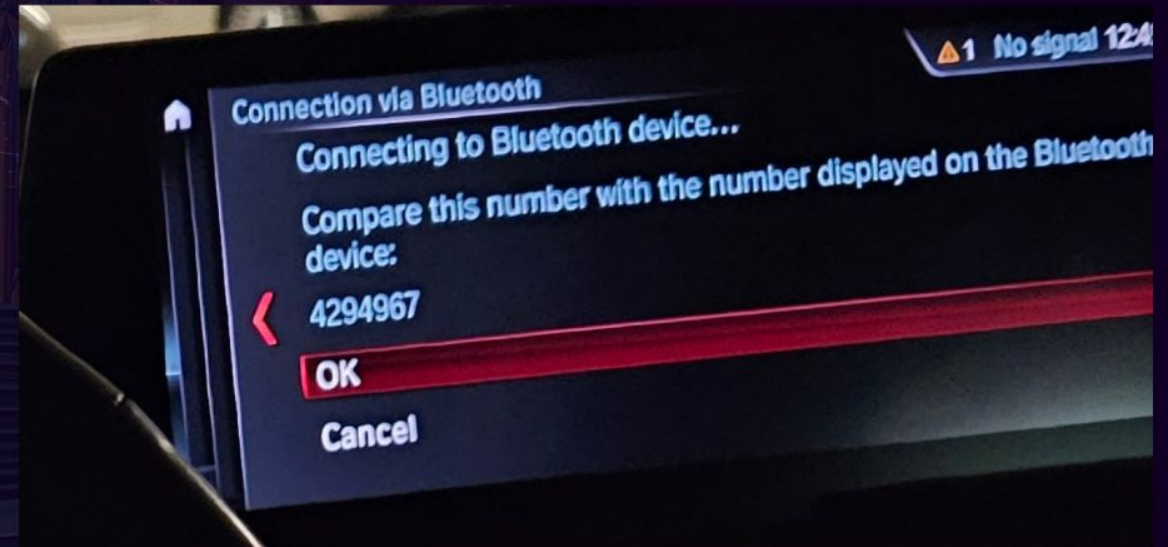
Hyundai



Renault



Audi



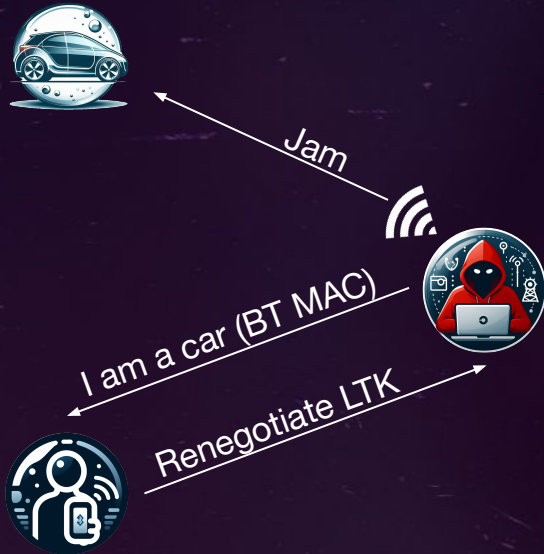
BMW



From your car to the bank

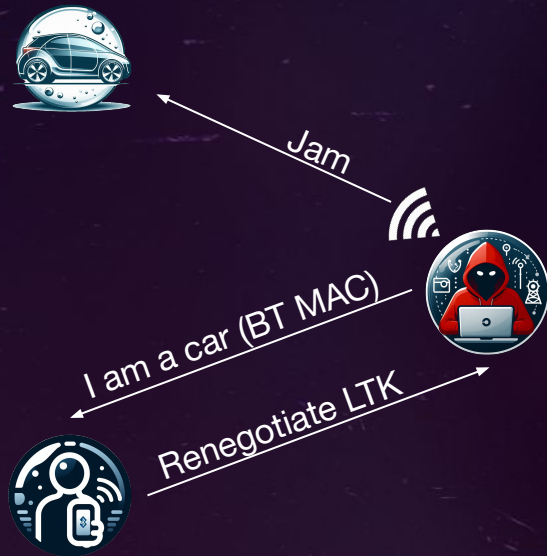
V - Establishing a MitM position

1. Selective Jamming

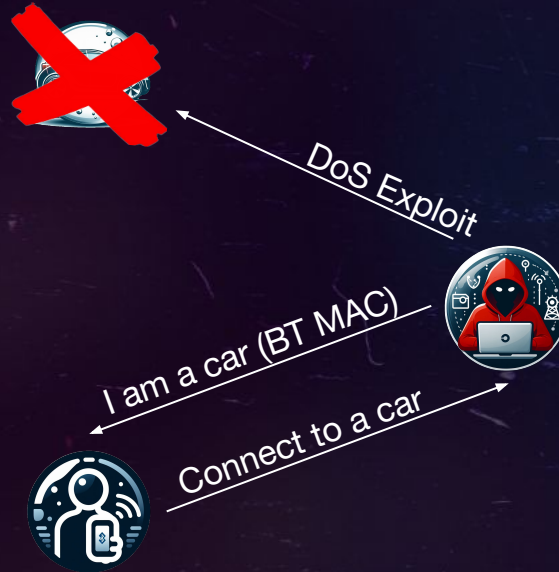


V - Establishing a MitM position

1. Selective Jamming

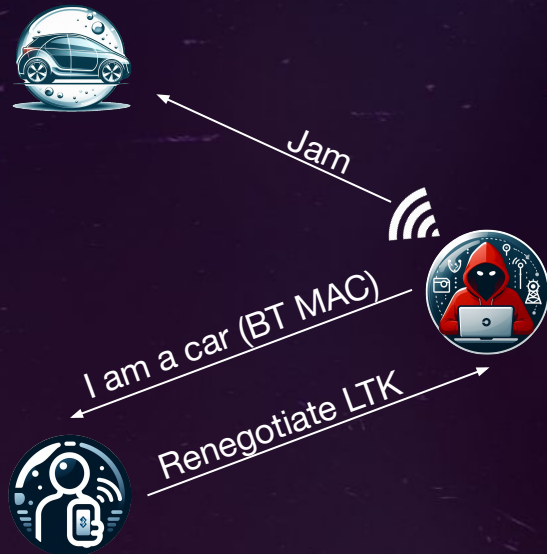


2. DoS and advertise as a car

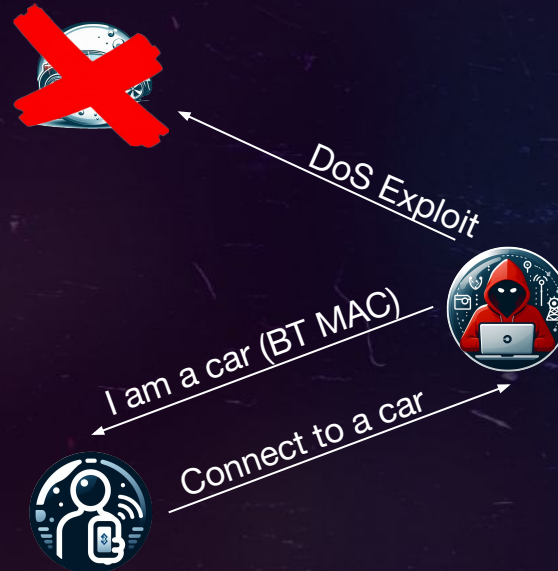


V - Establishing a MitM position

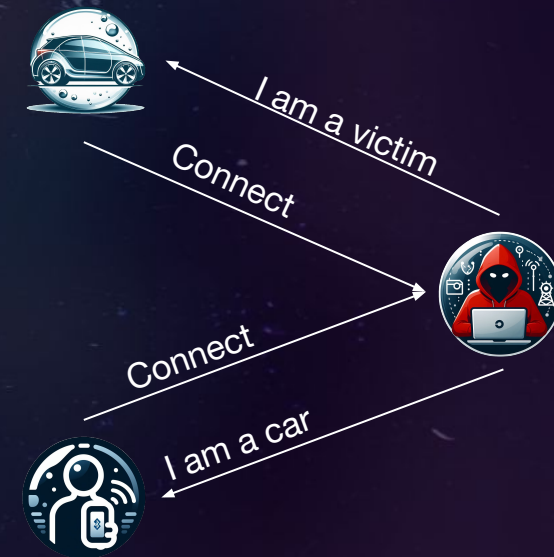
1. Selective Jamming



2. DoS and advertise as a car



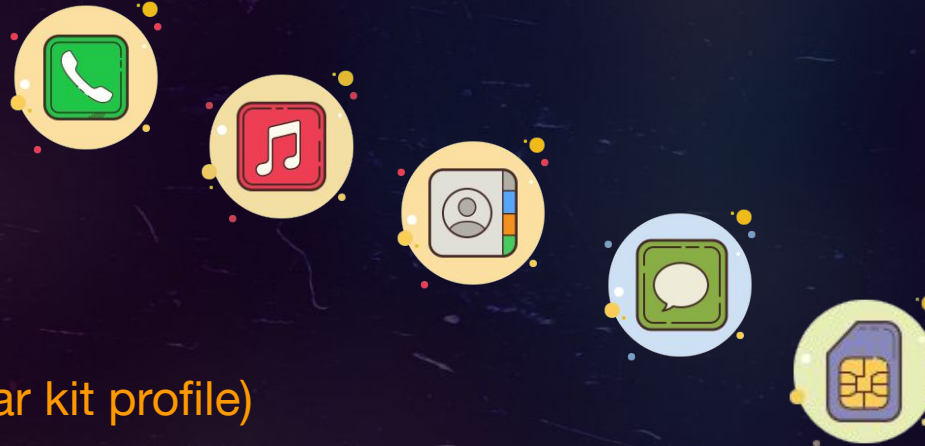
3. Pre-commit with different MAC addr. Or exploit other MitM vulnerabilities



- Discover MAC addresses either by:
 - simply listening
 - via Blue's Clues¹² which gets MAC addresses of any BC devices with USRP and Ubertooth even in non-discoverable mode.
- Gets you a first click!

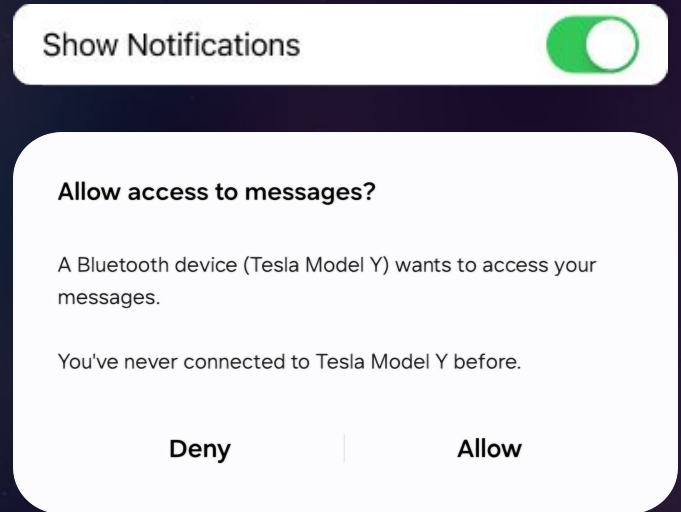
V - What can we do with MitM?

- “Escape” Bluetooth “sandbox”
- Switch focus to the Phones
- Phones typically have:
 - HFP -> making calls
 - A2DP -> playing music
 - PBAP -> sharing contacts
 - MAP -> sharing messages (Car kit profile)
 - SAP* -> full access to the SIM card (Car kit profile)



V - What can we do with MitM?

- “Escape” Bluetooth “sandbox”
- Switch focus to the Phones
- Phones typically have:
 - HFP -> making calls
 - A2DP -> playing music
 - PBAP -> sharing contacts
 - MAP -> sharing messages (Car kit profile)
 - SAP* -> full access to the SIM card (Car kit profile)
- MAP is the most interesting
 - We can extract messages of different types: IM, SMS_GSM, SMS_CDMA, EMAIL
 - We can also send messages :) Though we were able to only send an SMS so far
 - The UX is helpful



V - MAP Account hijack attack

- MitM established*
(1-click)
- MAP request (1-click)



Adversary in
MitM position

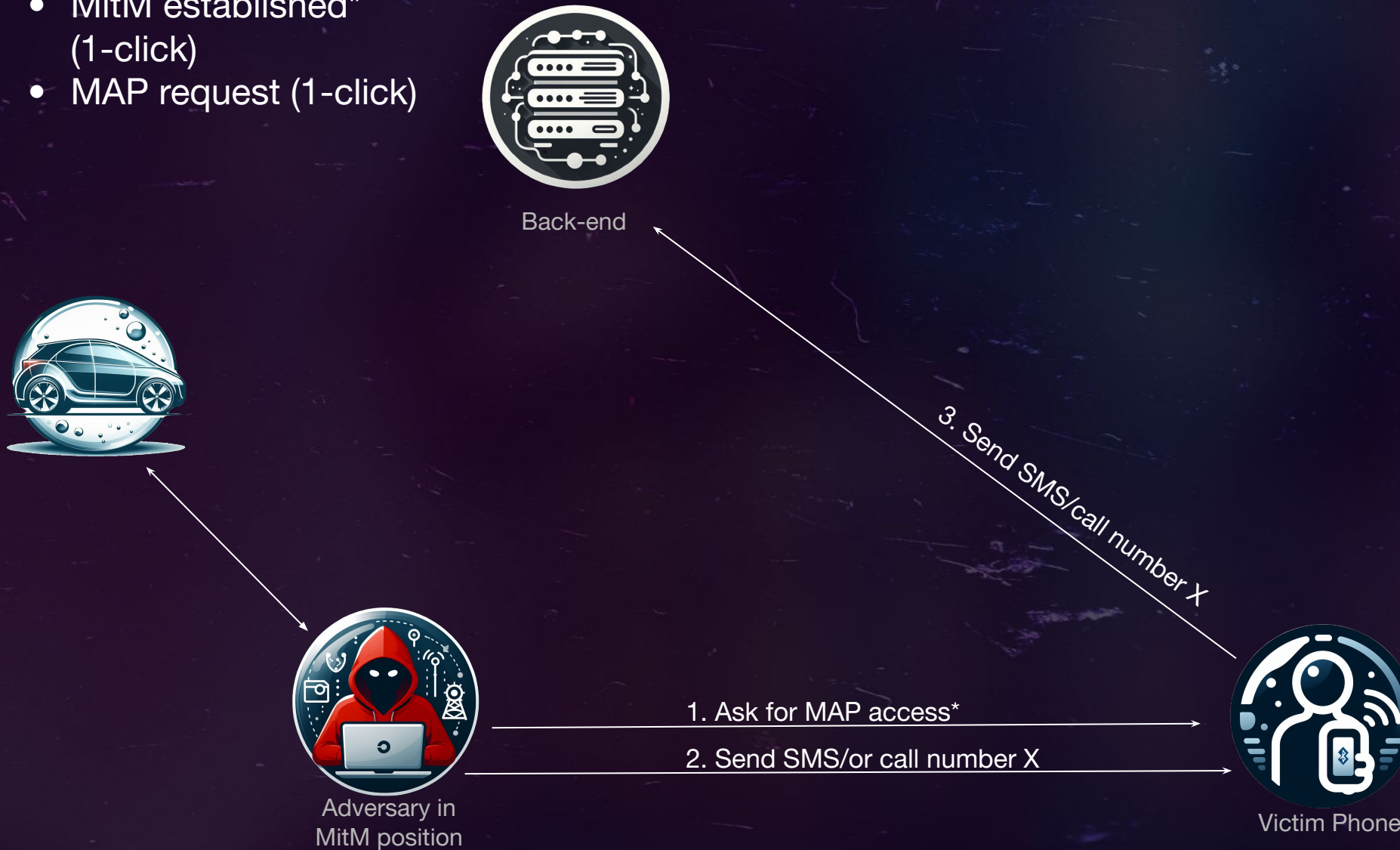
1. Ask for MAP access*



Victim Phone

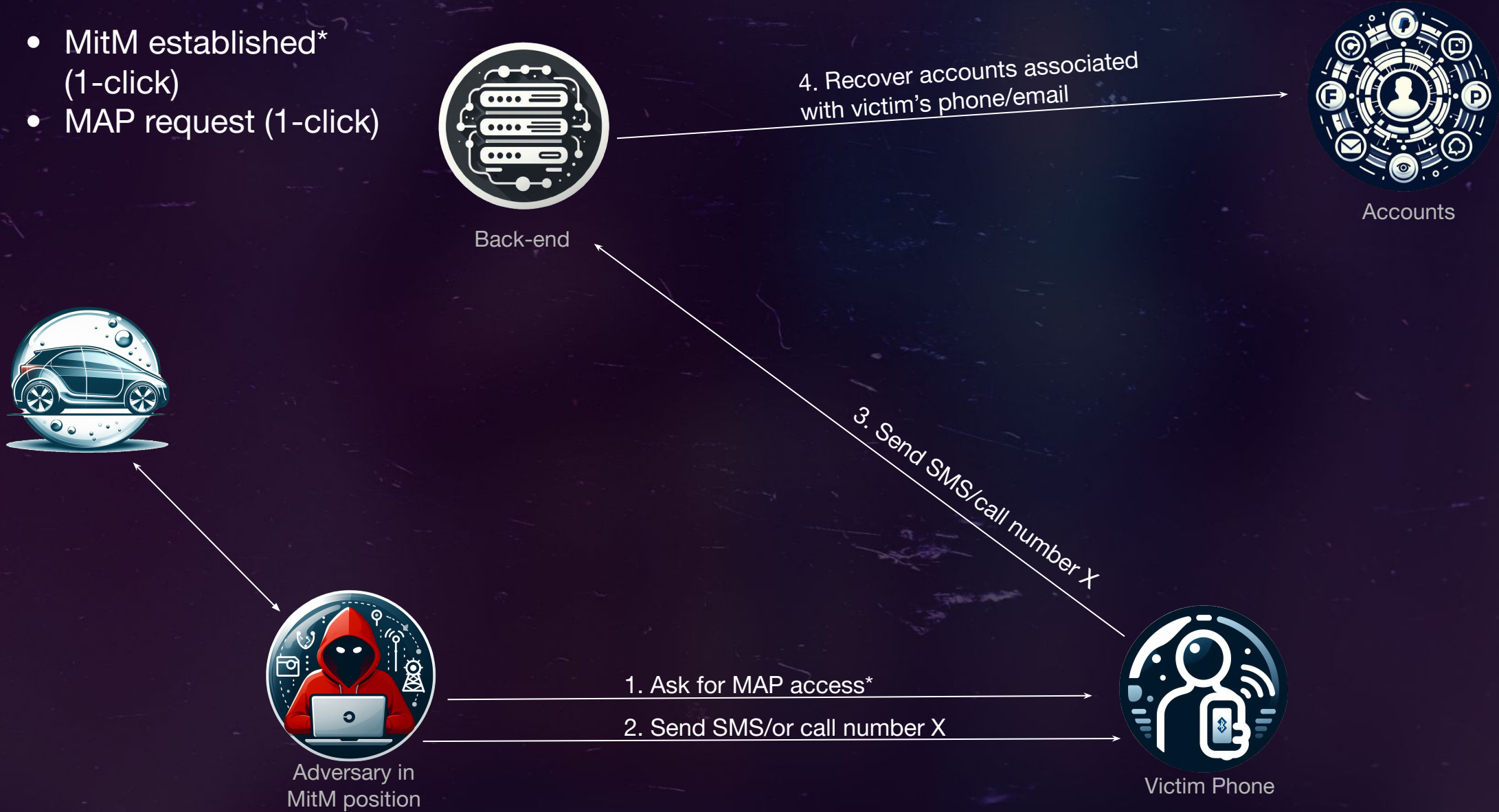
V - MAP Account hijack attack

- MitM established*
(1-click)
- MAP request (1-click)



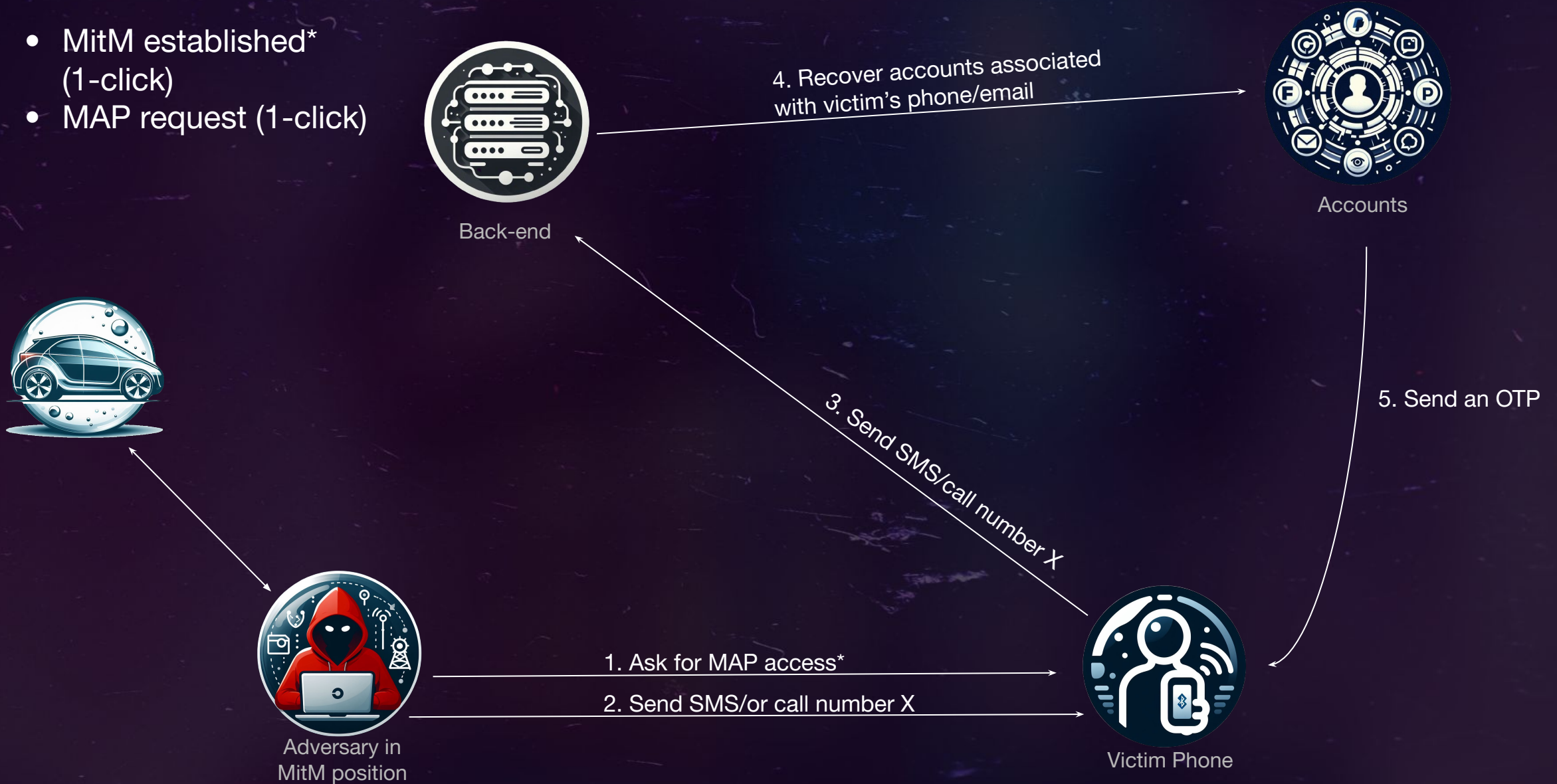
V - MAP Account hijack attack

- MitM established*
(1-click)
- MAP request (1-click)



V - MAP Account hijack attack

- MitM established*
(1-click)
- MAP request (1-click)



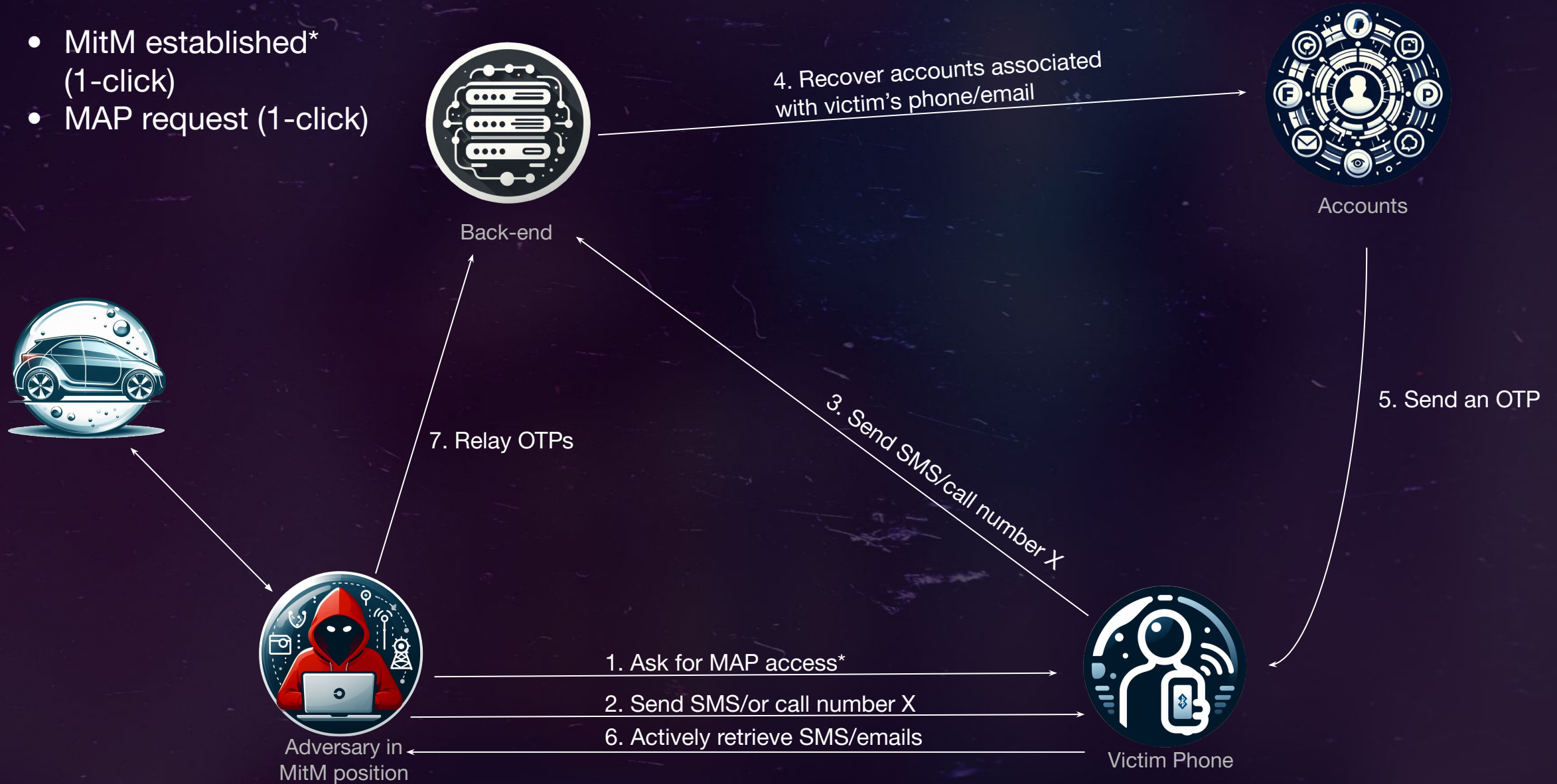
V - MAP Account hijack attack

- MitM established*
(1-click)
- MAP request (1-click)



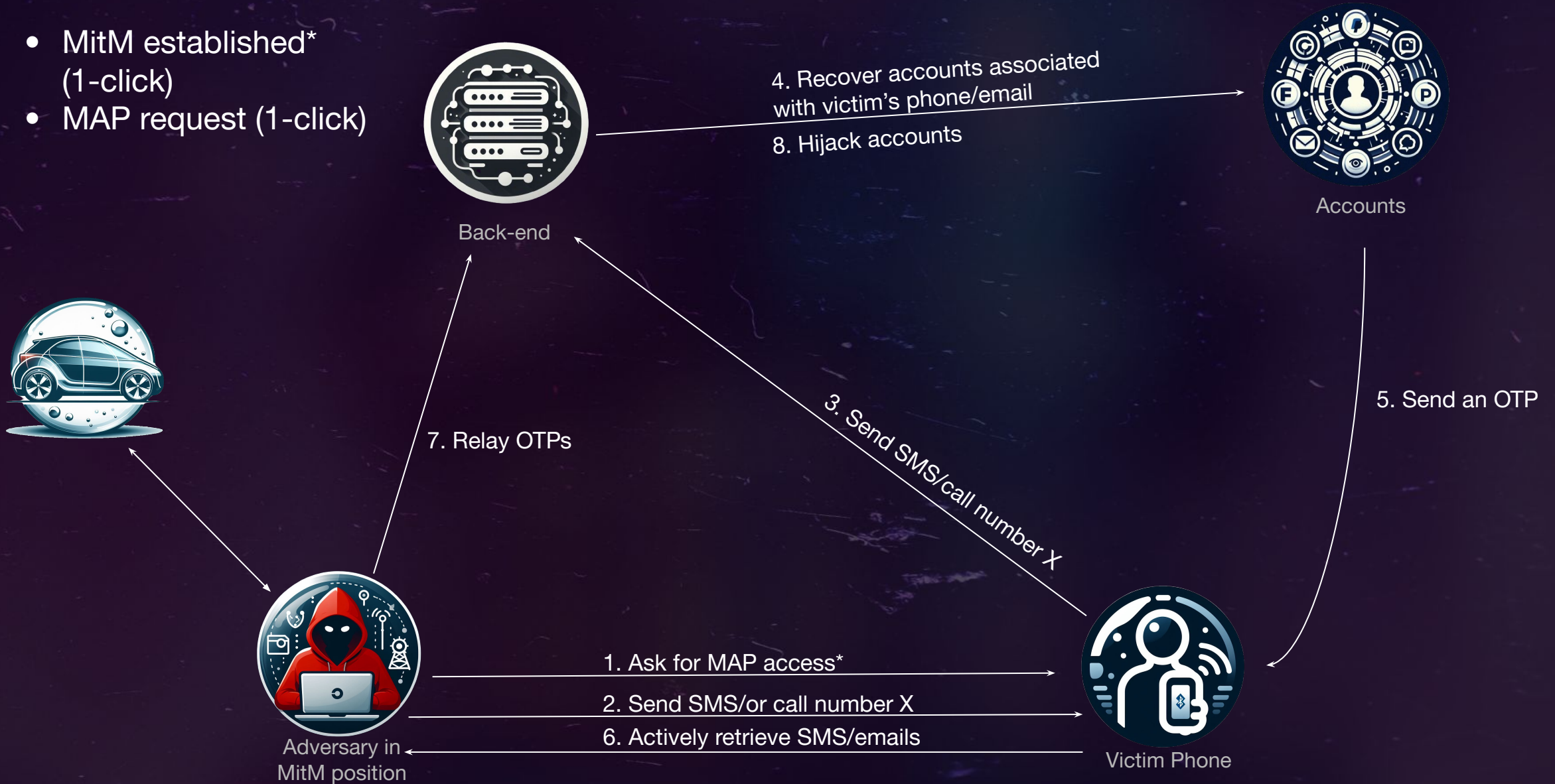
V - MAP Account hijack attack

- MitM established*
(1-click)
- MAP request (1-click)



V - MAP Account hijack attack

- MitM established*
(1-click)
- MAP request (1-click)





Complex MitM
setup



Just connect
directly

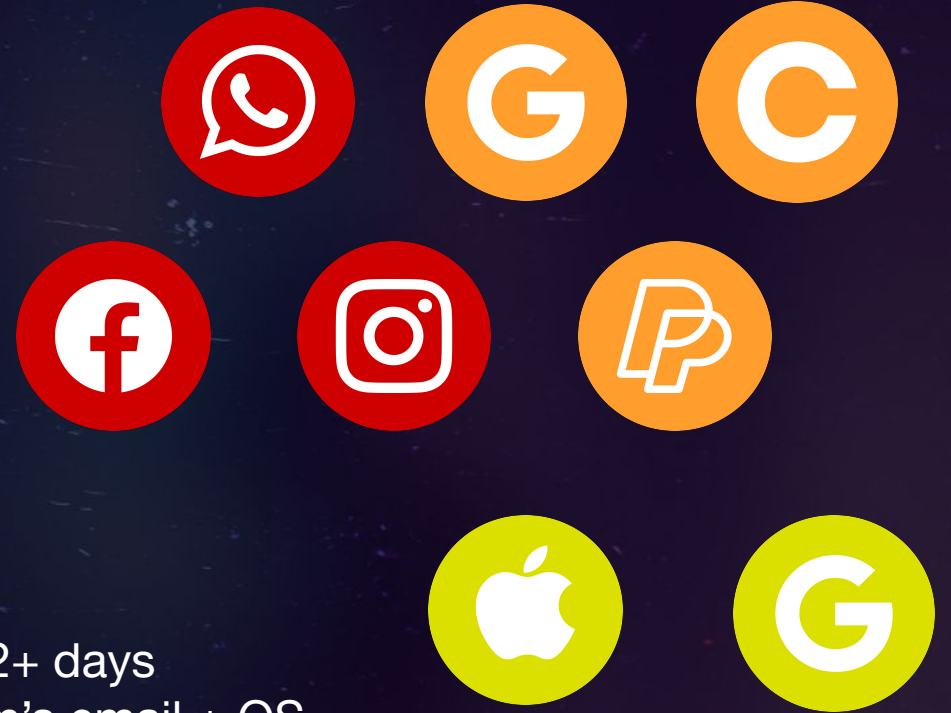
V - MAP Account hijack attack

- MitM is not really needed
- Leak phone numbers and emails by checking previous SMS messages or doing OSINT
- MAP authorization is not needed in some cases
 - 1 to 2 click generic account takeover attack



V - What can we hijack?

- Bypass MFA
- Services that rely primarily on SMS-based OTP
 - Meta
- Trigger SMS-based OTP by knowing the info(e.g. email):
 - Paypal (email)
 - Coinbase (email)
 - Google Account (email)
 - Apps to control the vehicles
- Sometimes difficult:
 - AppleID -> phishing only! As the victim is notified, takes 2+ days
 - Google Account (logged in on a device)-> know the victim's email + OS type. Possible as we have a similar IP and location as the victim



V - Android (Samsung) example

1. Connect and Pair



Always pairable*

Bluetooth pairing request

Pair with Tesla Model Y?

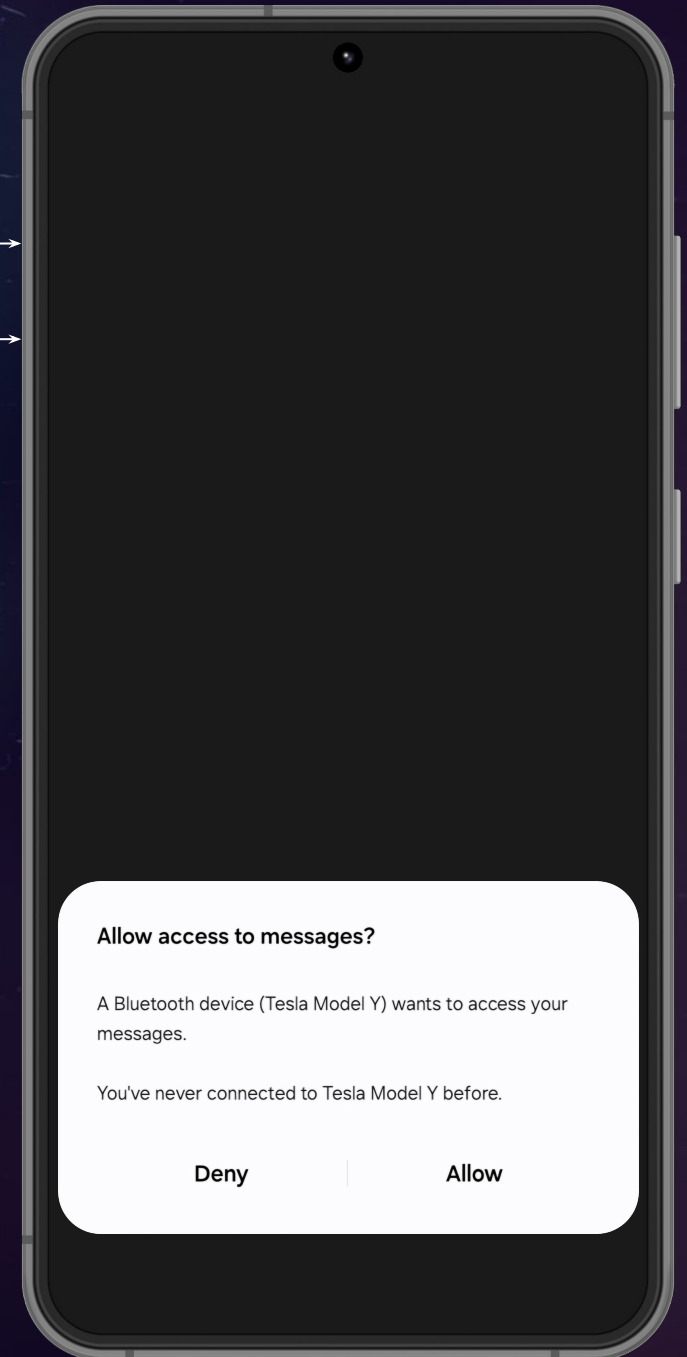
Cancel

Pair

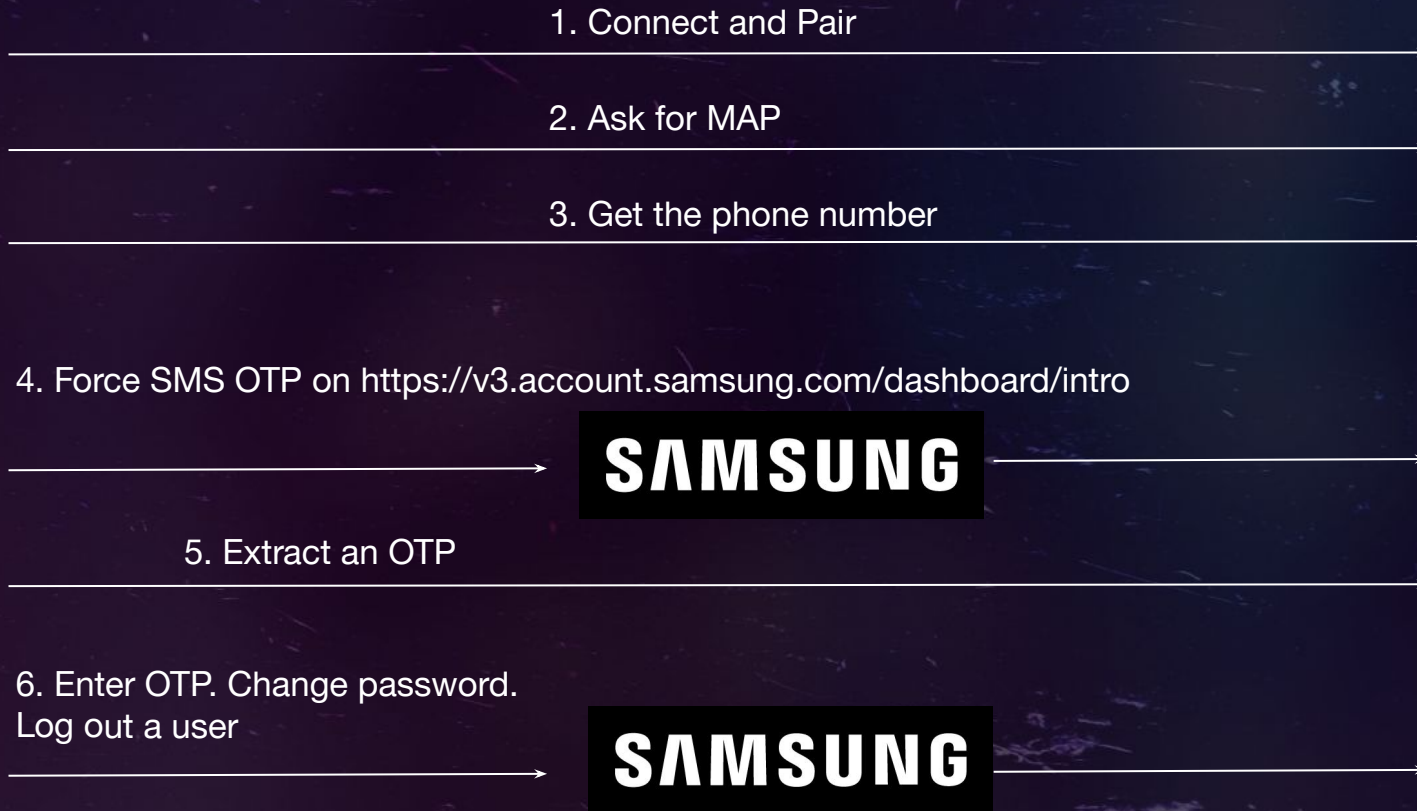
V - Android (Samsung) example

1. Connect and Pair

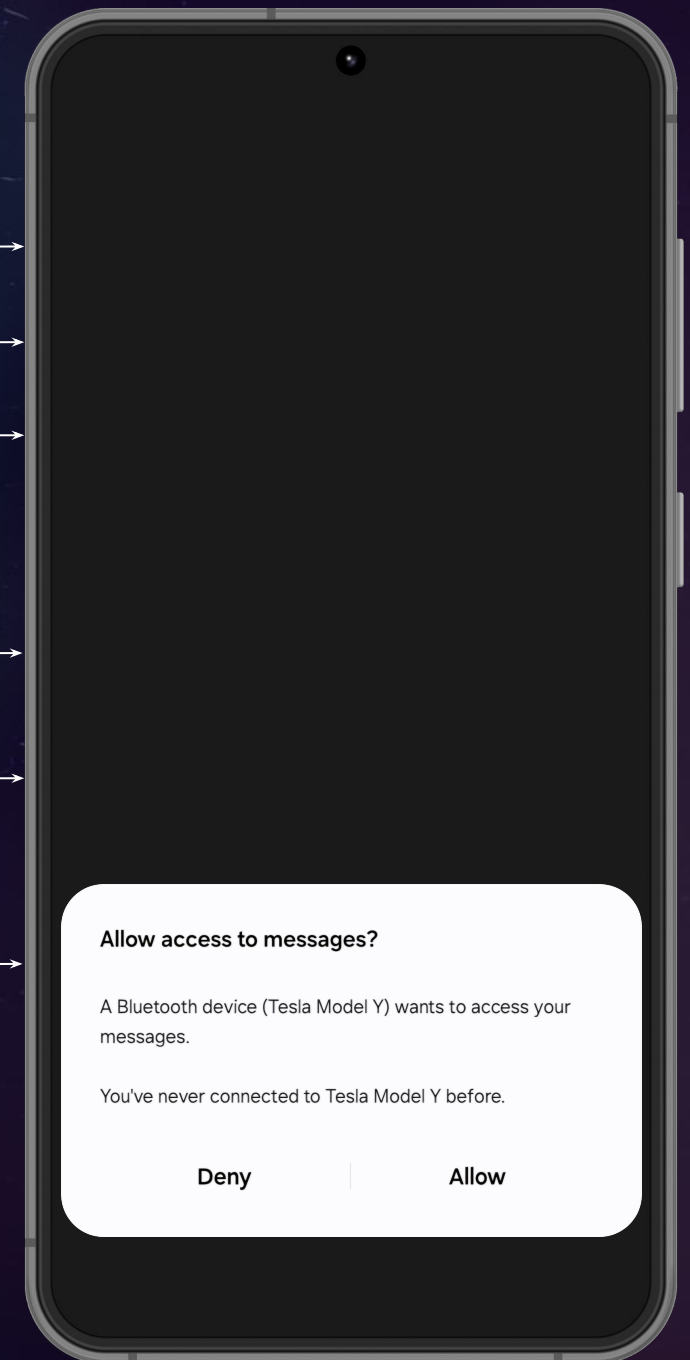
2. Ask for MAP



V - Android (Samsung) example - 1day?

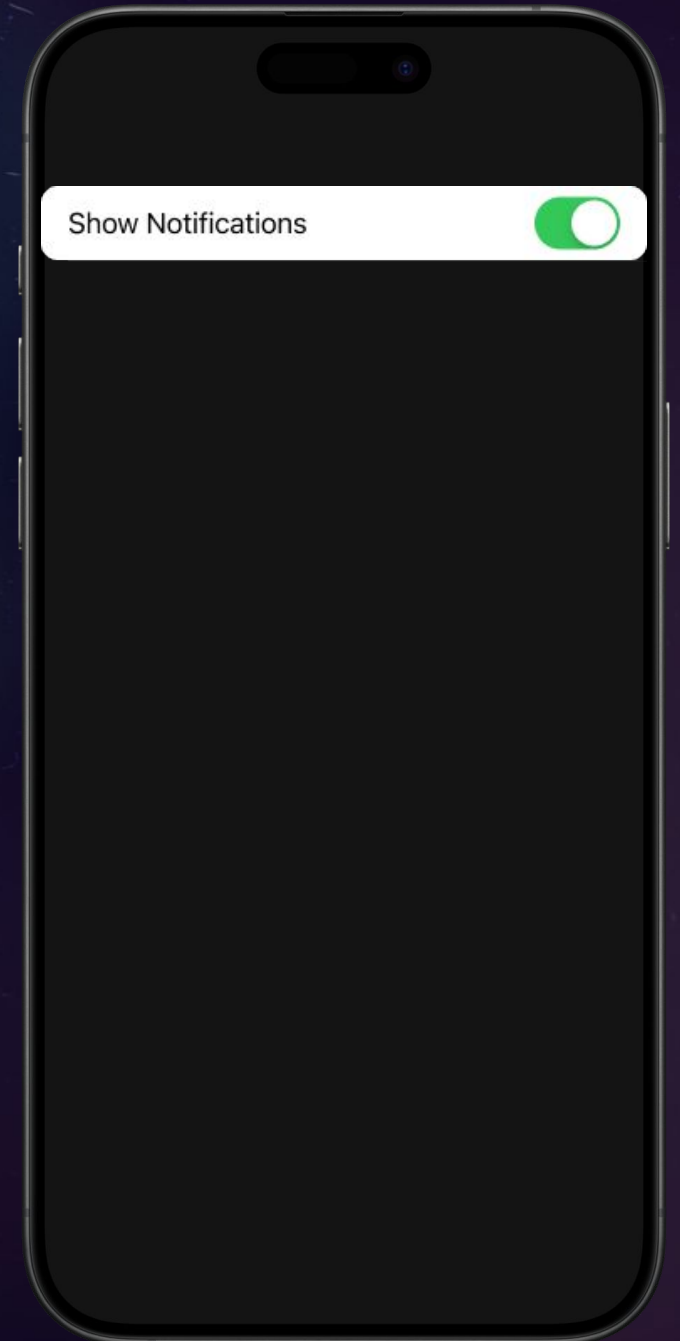


- 2-click attack
- Google working on a patch/hardening for Android
- Samsung patched Samsung Account services in June 2024(they said they fixed the vuln in November 2023???? before I reported)



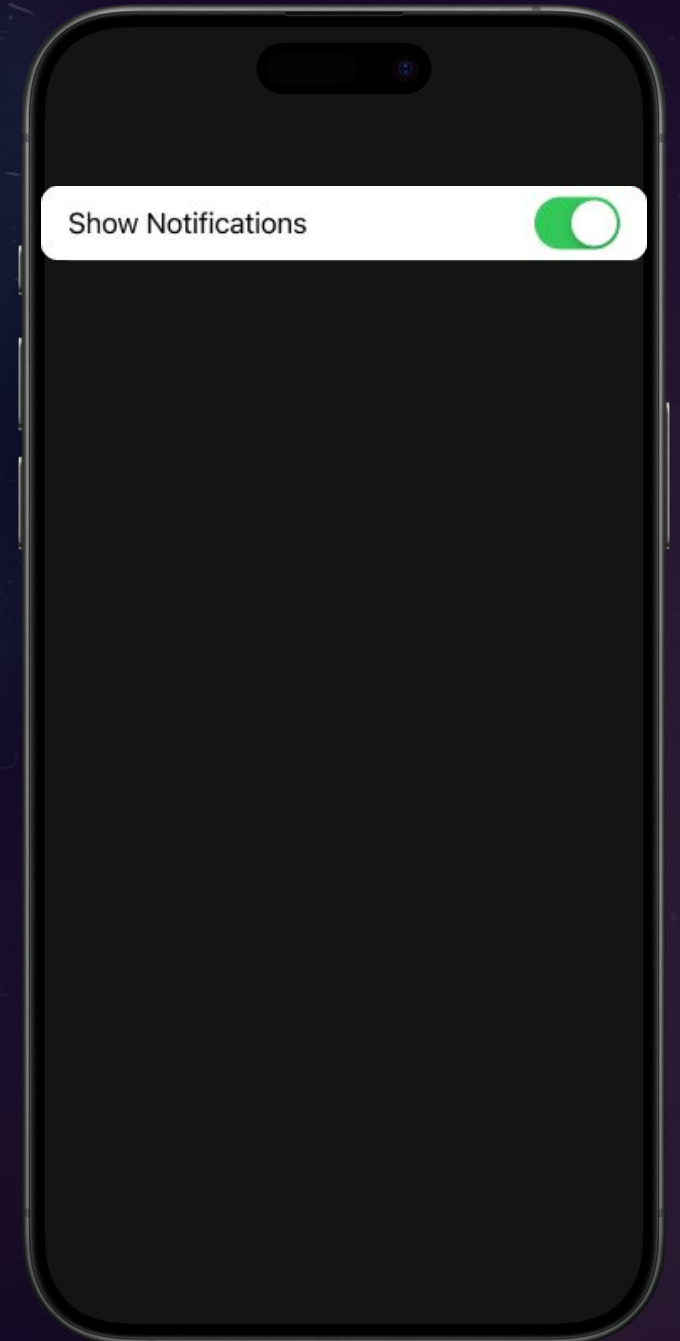
V - Dropping a 1-day for iOS

- You **cannot** exploit MAP the same way on iOS. The user needs to explicitly allow Notifications for a new device in the Settings!



V - Dropping a 1-day for iOS

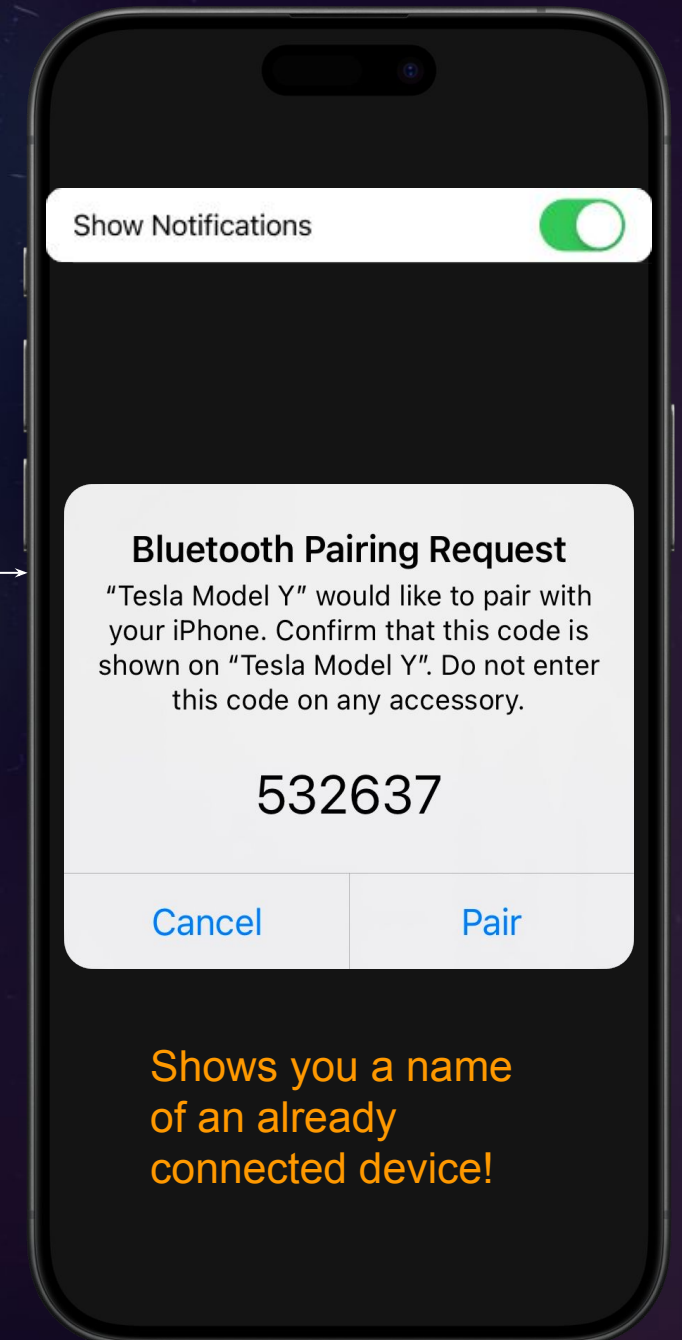
- You **cannot** exploit MAP the same way on iOS. The user needs to explicitly allow Notifications for a new device in the Settings!
- **But** what if we can renegotiate a connection for an already connected device with Notifications permissions?



V - Dropping a 1-day for iOS

- You **cannot** exploit MAP the same way on iOS. The user needs to explicitly allow Notifications for a new device in the Settings!
- **But** what if we can renegotiate a connection for an already connected device with Notifications permissions?

1. Spoof MAC addr of an already connected device with MAP permissions and repair



V - Dropping a 1-day for iOS

- You **cannot** exploit MAP the same way on iOS. The user needs to explicitly allow Notifications for a new device in the Settings!
- **But** what if we can renegotiate a connection for an already connected device with Notifications permissions?

1. Spoof MAC addr of an already connected device with MAP permissions and repair

2. Get the phone number

3. Force SMS OTP on <https://www.facebook.com/login/identify/?ctx=recover>



4. Extract an OTP



5. Enter OTP. Change password.
Log out a user



V - Dropping a 1-day for iOS

- AppleID
 - Inject SMS messages -> Phishing and stealing SMS OTP with MAP attack (\$22k stolen SIM Swap)¹
 - Similar to SIM Swap attack
- We can also hijack other applications like Paypal and Coinbase:)



1. <https://www.blick.ch/digital/bund-warnt-vor-fieser-masche-nur-ein-falscher-klick-kostet-20000-franken-id19780606.html>

Blick | DE | FR

Nur ein falscher Klick kostet **20'000** Franken

Ein Fall, der dem Bundesamt für Cybersicherheit kürzlich gemeldet wurde, zeigt, wie wichtig es ist, sein digitales Leben gut zu schützen.

Publiziert: 27.05.2024 um 12:43 Uhr | Aktualisiert: 27.05.2024 um 14:02 Uhr

f X WhatsApp Email Link

Q 51

Vorlesefunktion derzeit nicht verfügbar

Teile uns deine Meinung zur Vorlesefunktion mit. [Zur kurzen Umfrage.](#)

A photograph showing several SIM cards of various colors (white, gold, red) and sizes (standard, micro-SIM) scattered on a light surface. The cards are arranged in a somewhat circular pattern, with some overlapping. The gold contacts are visible on the back of the cards. The image is framed by a dark border with navigation arrows on the left and right sides.

AFP

4/5 Im Portal erstellten sie dann eine elektronische SIM (e-SIM) und konnten fortan alle SMS

V - Dropping a 1-day for iOS

- **Not Fixed** as of iOS 17.6 and **is not going to be fixed!**
- Apple's quote: 'The users are "safe" because they are shown a pairing prompt' - or simply -> 1-click away from their accounts being stolen



We do not see an issue that needs to be addressed.



WHAT 🤔 DO 🤔 YOU 🤔 MEAN? 🤔

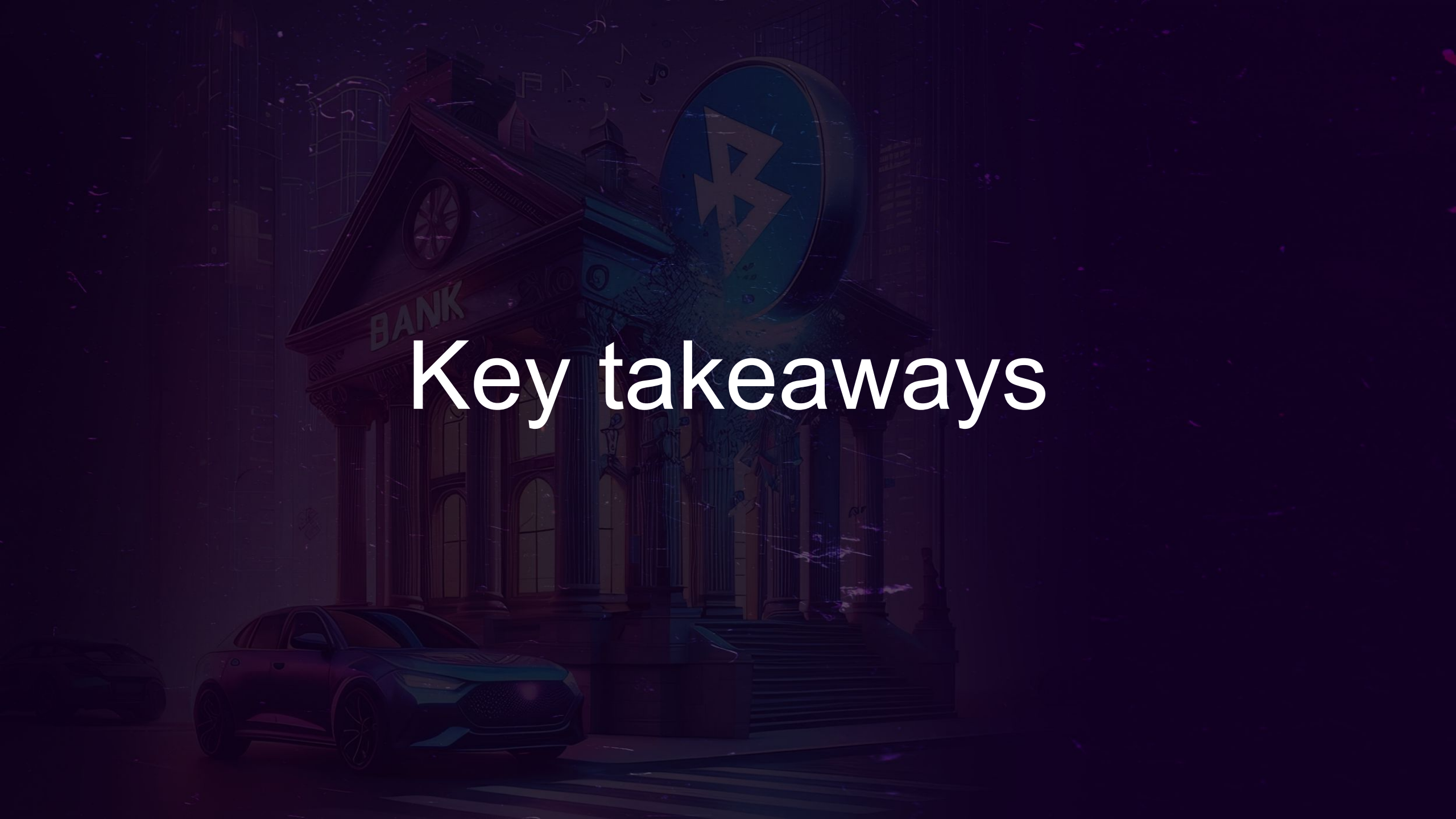
V - Tool for MAP Account Hijack attack

- At least 51% of smartphone market worldwide¹ is affected
- Allows you to
 - Retrieve and send SMS messages
 - Looks for emails and phone numbers on the device
 - Connect the tool to your infrastructure to relay SMS messages

<https://github.com/sgxgsx/mapAccountHijack>



1. <https://gs.statcounter.com/vendor-market-share/mobile>



Key takeaways

VI - Key takeaways

- Even the newest cars are shipped with protocol-level Bluetooth vulnerabilities -- and we can't easily fix this.
- Pairing securely is the only safeguard but re-pairing might be malicious too.
- Relying just on SMS-based OTPs might be risky for the end-users.

VI - Key takeaways

- Even the newest cars are shipped with protocol-level Bluetooth vulnerabilities -- and we can't easily fix this.
 - Pairing securely is the only safeguard but re-pairing might be malicious too.
 - Relying just on SMS-based OTPs might be risky for the end-users.
-
- Much of Bluetooth is fundamentally insecure, both the standards and implementations
 - Use BlueToolkit to gauge the security posture of BT products!
 - And we cannot be liable for any damages ;)

VI - Going beyond...

- BlueToolkit can of course be used for any Bluetooth (Classic) system
- We also tried it out on our avionics lab with real aircraft hardware



Index	Exploit	Result	Data
1	au_rand_flooding	Not vulnerable	0
2	feature_response_flooding	Not vulnerable	0
3	braktooth_knob	Vulnerable	vulnerable
4	feature_req_ping_pong	Not vulnerable	3
5	reconnaissance_SC_supported	Vulnerable	No Secure Connections supported
6	reconnaissance_possible_BLUR	Not vulnerable	No LE supported, Cross transport attacks are not going to work
7	reconnaissance_SSP_supported	Vulnerable	SSP supported, weak cryptography is used

Q&A

Scan to
discover more

<https://github.com/sgxgsx>

Contact: ysoschwytz@protonmail.com

Design: ux.uidesigns@protonmail.com



The background is a dark, atmospheric illustration of a classical bank building. The building has a triangular pediment with a circular window and the word "BANK" inscribed on it. A large, glowing blue circular logo with a white geometric symbol is positioned to the right of the building. In the foreground, a modern, dark-colored car is parked on the left. The word "Appendix" is written in a large, white, sans-serif font across the center of the image.

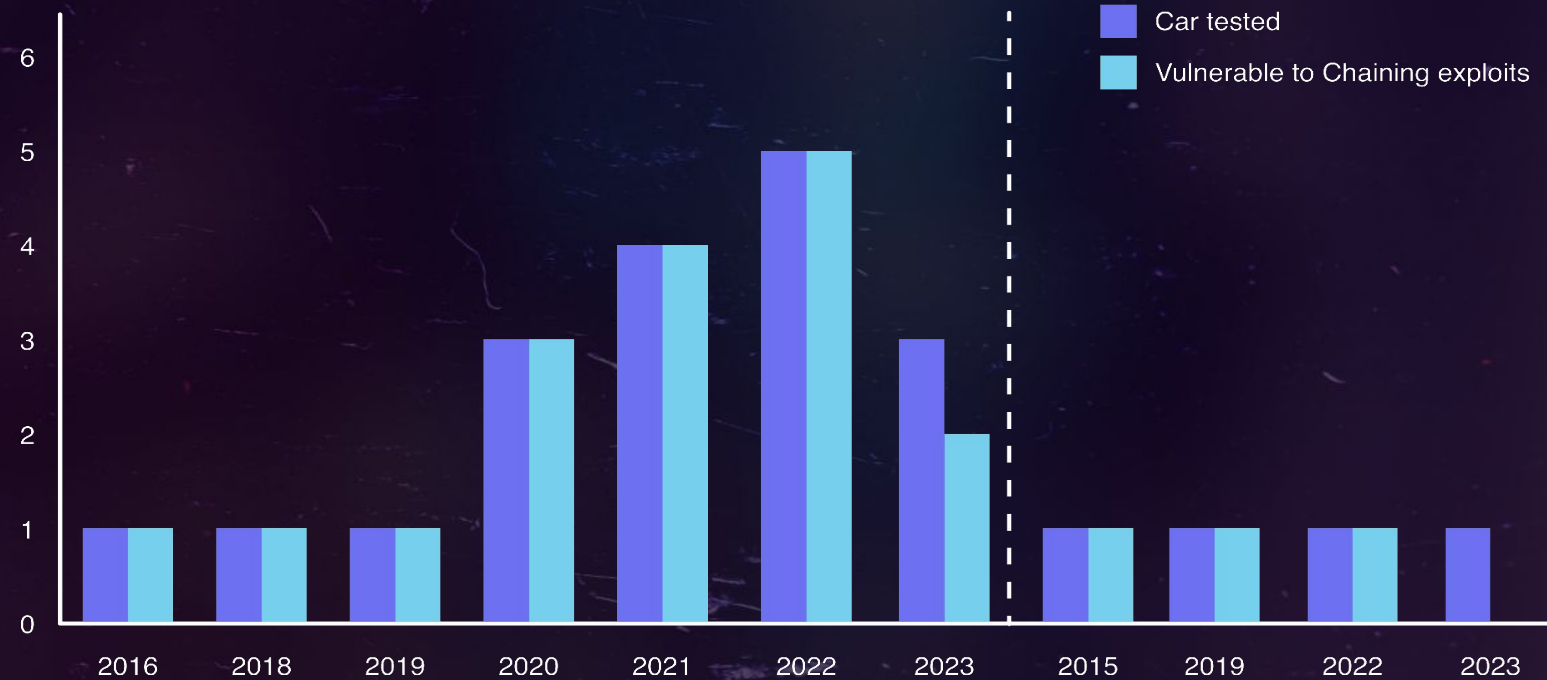
Appendix

Licence

All icons except those on slides 14 and 58 - are custom created and their usage is permitted in non-commercial use-cases (personal use only) with a requirement of attribution to ux.uidesigns@protonmail.com

IV - Known weaknesses exist in practically all cars studied

- 4 tests in total
- IVI not rebootable (DoS)
- Always pairable
- SC not supported
- IVI should initiate pairing

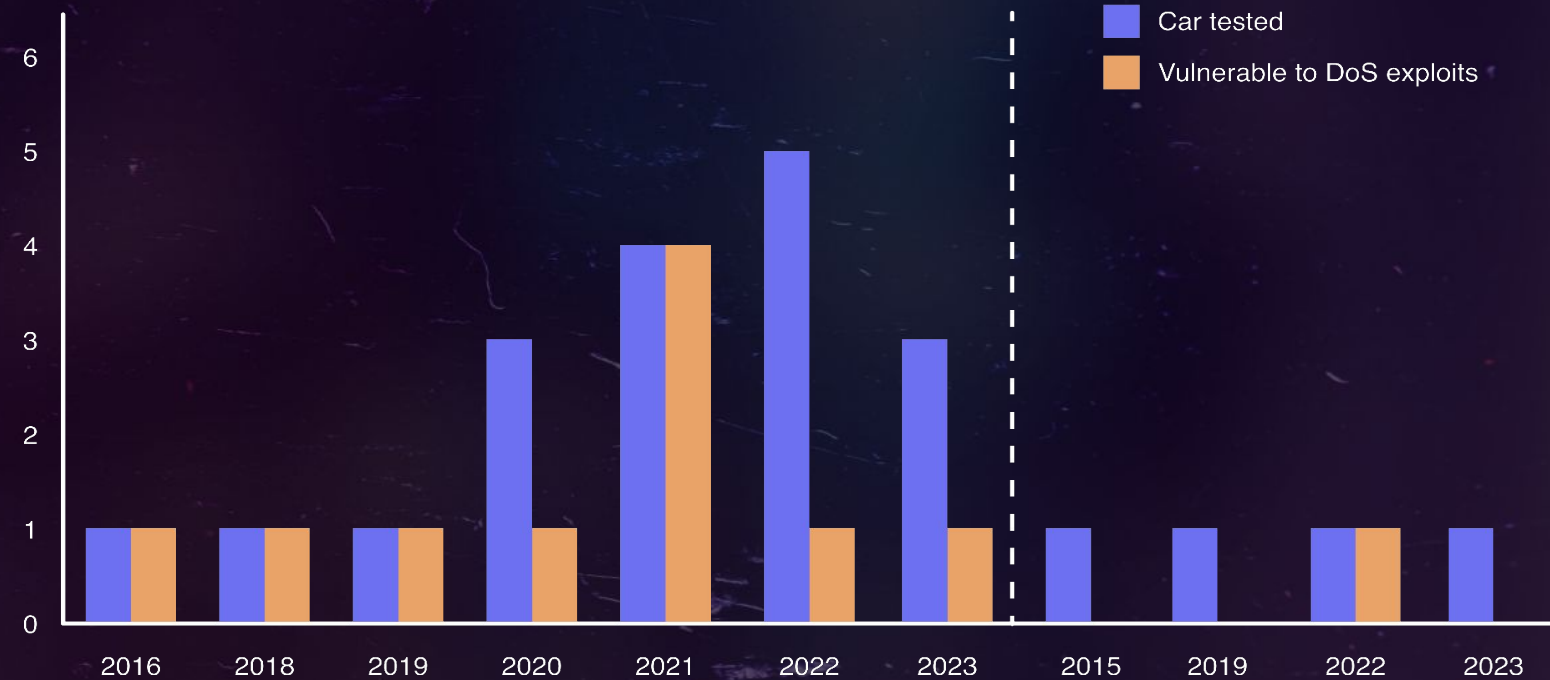


IV - DoS

- Helpful for MitM
- 21 exploits in total

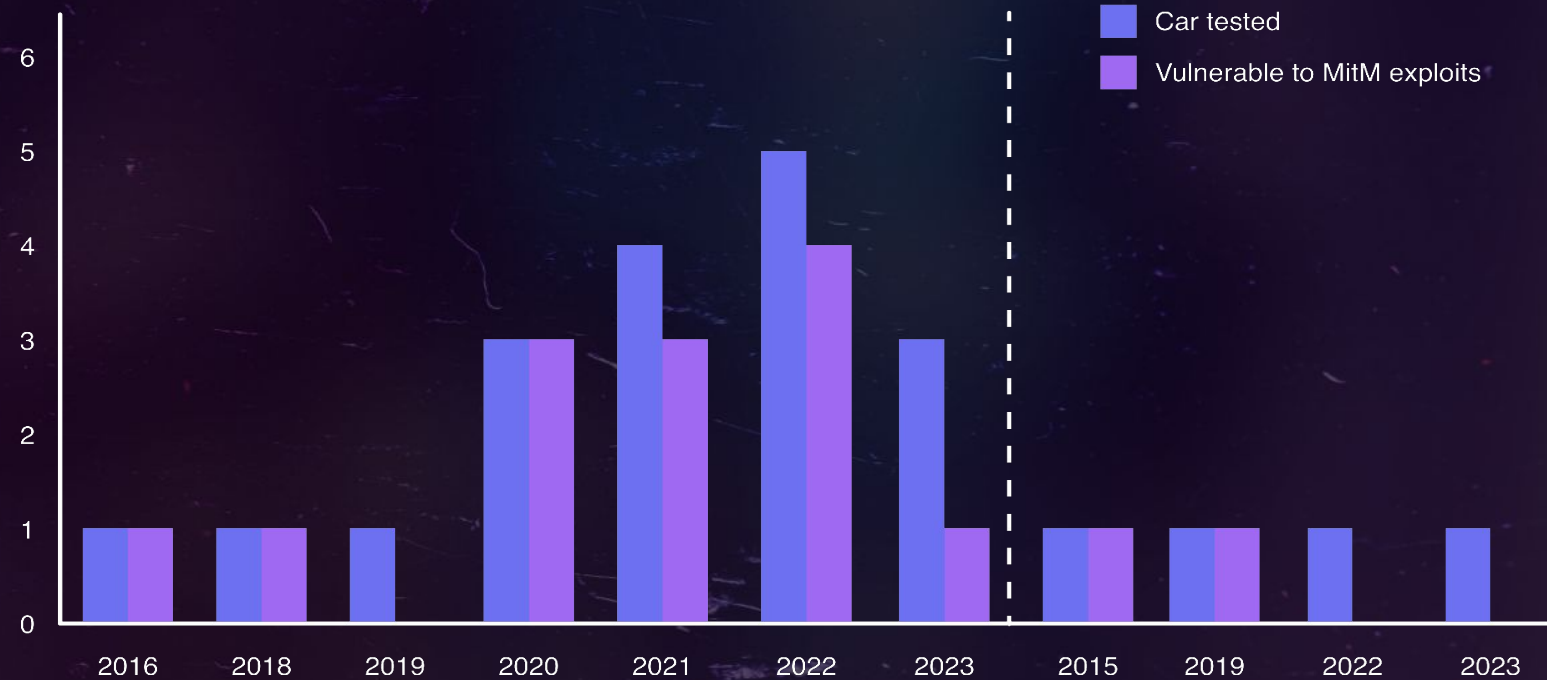
- Most found:

- duplicated_encapsulated_payload
- duplicated_iocap
- feature_req_ping_pong
- invalid_max_slot
- invalid_timing_accuracy
- Imp_auto_rate_overflow
- Imp_invalid_transport
- Imp_max_slot_overflow
- Imp_overflow_2dh1
- Imp_overflow_dm1
- sdp_oversized_element_size
- sdp_unknown_element
- truncated_Imp_accepted
- truncated_sco_request
- wrong_encapsulated_payload



IV - MitM attacks prevail

- 8 exploits in total
- Make attacks look smooth
- Most found:
 - E0 Algorithm is used (BT vers)
 - KNOB
 - Legacy Pairing enabled (no SSP)
 - NiNo
 - Vehicular NiNo
 - Insecure NC implementation



IV - Code Executions and Information leaks are common

- 10 exploits in total
- Most found:
 - CVE-2018-19860
 - Contact extractor

